



Cloud Based Managed Security Service Provider

2023W-T4 AIP Group D

Final Report

Submitted by

Team D1

Parthkumar Patel (500201559)

Varun Gulati (500199939)

Manpreet Kaur (500200665)

Haroon John (500200967)

Nikhilkumar Dobariya (500200627)

Project Advisor

Ahmad Sharif

9th April 2023

Table of Contents

Abstract:	4
Introduction	5
Purpose:.....	5
Background:	5
Importance of handling sensitive information:	5
Hypothesis And Research Questions:	6
Literature Review	7
Overview of data security:	7
Best practices for securing sensitive data:	8
Procedures to protect data:.....	9
Case studies:.....	10
Data Breach at Anthem Inc.:.....	10
Data Breach at the NHS:	10
Method	11
Evaluating current security measures:	11
Data collection Methods:	12
Detailed plan:	12
Security Policy:.....	17
Findings	18
Security Assessment:	18
Identification of Vulnerabilities:.....	18
Physical security:	18
Network Security:	19
User Security:.....	19
Recommendations:.....	19
Incident management standards:	20
Vulnerability management standards:.....	21
Layout	22
Discussion:	34
Interpretation of Findings:	34
Implication:	34
Conclusion:	35
Summary of key findings:.....	35
Business Impact:	35

Effectiveness:	36
Recommendation.....	37
Introduction.....	37
Timeline:	37
Suggestions for future research:.....	38
Reference:	39
Appendices A.....	45
Project Charter	45

Abstract:

The purpose of the project is to evaluate Khupragenics' present security procedures and provide a thorough plan to boost consumer confidence in the company's capacity to protect sensitive genetic data. The analysis highlights potential security threats and weaknesses in the organisation's data management procedures and offers doable recommendations to boost data security standards.

The report's major conclusions show that, despite Khupragenics' use of a number of security measures to safeguard private genetic data, the company's data management procedures may still be vulnerable. The paper emphasises the significance of putting in place a thorough security plan, which should include frequent risk assessments, personnel training, and the use of secure data transfer techniques.

The project also highlights the moral and legal issues that surround the processing of private genetic data, and it advises Khupragenics to evaluate and revise its privacy policy to take these issues into account. The paper also urges the development of reliable access controls, disaster recovery strategies, and data encryption techniques.

Overall, the study comes to the conclusion that putting in place a thorough data security plan will boost client confidence in Khupragenics' capacity to safeguard private genetic data, resulting in better patient results and a rise in demand for the firm's services. The research advises Khupragenics to adopt a proactive strategy for data security by routinely evaluating and enhancing its security precautions over time.

Introduction

Purpose:

The goal of this project is to create a comprehensive plan to increase consumer trust in the protection of sensitive information at Khupragenics. This contains newborn genome sequencing data, which is used to find disease-causing mutations. The strategy will prioritize the protection of personal information, such as patient data and medical records, as well as ensuring that the company's systems and procedures satisfy the highest data security and privacy requirements. The ultimate objective is to give medical professionals and parents with peace of mind, as well as to encourage the proper use of genetic sequencing to enhance baby health outcomes.

Background:

Tanvi Khushi and Arun Prajapati founded the biotech startup business Khupragenics, which has its headquarters in Toronto, Canada. The company's main goal is to employ genome sequencing to find disease-causing mutations in infants, especially those born with uncommon and complicated medical disorders. Khupragenics wants to give medical professionals and parents access to potentially life-saving therapeutic intervention options by utilising cutting-edge genomic sequencing technologies.

Khupragenics' goal is to enhance infants' health outcomes by offering precise and prompt genetic testing services. To promote the diagnosis and treatment of uncommon and complicated diseases, the firm aspires to be a pioneer in the fields of genomic sequencing and personalised medicine.

The business offers neonatal and baby genetic testing, with an emphasis on finding abnormalities that cause disease. Khupragenics collaborates closely with medical specialists, giving them reliable results quickly to help with diagnosis and treatment. In order to help parents better comprehend the outcomes and implications of genetic testing, the organisation also provides genetic counselling services.

With a strong focus on patient privacy and confidentiality, Khupragenics' mission is to give infants and their families with individualized, comprehensive treatment. The business is dedicated to protecting the privacy and security of sensitive genetic information by utilising the most recent technologies and best practises.

Importance of handling sensitive information:

Maintaining patient privacy and confidentiality, guarding against identity theft and fraud, and guaranteeing the ethical use of this highly personal information all depend on the secure processing of sensitive genetic data.

Genetic data is distinct and can offer extremely private and sensitive details about a person's health, ancestry, and potential risks for contracting particular diseases. Important medical decisions, such as early intervention and treatment, can be made using this information, which can have a big impact on a person's health and wellbeing.

However, there are important hazards associated with the handling and sharing of genetic information. Genetic data unauthorised access can lead to stigmatization, discrimination, and loss

of privacy. Genetic data may potentially be utilised fraudulently for things like identity theft and insurance fraud.

Because of this, it's critical that organisations like Khupragenics that deal with private genetic data have strong security safeguards in place to guard against unauthorised access and guarantee patient confidentiality. This entails putting in place reliable risk assessments, encrypting all data, and teaching staff members appropriately on data privacy and security.

Secure handling of sensitive genetic data contributes to maintaining public confidence in healthcare services in addition to preserving patient privacy. In order to preserve the security and privacy of their personal and sensitive information, patients and their families need to have this assurance. Companies like Khupragenics can gain the trust of their patients and the general public by displaying a strong commitment to data privacy and security.

Hypothesis And Research Questions:

Customers will have more faith in Khupragenics' ability to protect sensitive genetic information as a result of the efficient execution of extensive data security policies, which will improve patient outcomes and boost demand for the company's services.

Research Questions:

- What security precautions is Khupragenics currently doing to safeguard private genetic data?
- What possible security flaws and threats exist in the company's data handling procedures?
- What ethical and legal issues are raised by the processing of private genetic data in the healthcare sector?
- How can Khupragenics put into place reliable data security procedures to lessen the risks and vulnerabilities found and guarantee the privacy and secrecy of private patient data?
- Effective data security policies may provide advantages such as better patient outcomes and a rise in demand for the business's services.
- How can Khupragenics gauge how well its data security protocols are working and how can they make improvements to them over time?

Literature Review

Overview of data security:

The healthcare business is extensively regulated, with strong data security and privacy norms and regulations (Clemens & Rosenbaum, 2017). Several laws, including the Health Insurance Portability and Accountability Act (HIPAA) of 1996, the Health Information Technology for Economic and Clinical Health (HITECH) Act of 2009, and the General Data Protection Regulation (GDPR) in the European Union, require healthcare providers to protect patient data (Clemens & Rosenbaum, 2017).

Healthcare data breaches have been more widespread in recent years, with over 500 data breaches documented in the United States alone in 2020. (Ponemon Institute, 2021). Major data breaches are mostly caused by human mistake, insider threats, and cyber assaults (Ponemon Institute, 2021). Data breaches in healthcare may have serious implications, including reputational harm, regulatory fines, and a loss of patient trust (Clemens & Rosenbaum, 2017).

Organizations must design a comprehensive security policy that encompasses administrative, physical, and technical precautions to prevent data breaches in healthcare (Clemens & Rosenbaum, 2017). Encryption, access limits, frequent security assessments, personnel training, and incident response planning are all best practises for protecting healthcare data (Clemens & Rosenbaum, 2017).

The processing of sensitive genetic information is controlled by a number of rules and regulations intended to safeguard patients' privacy and prevent the exploitation of this information. These guidelines and laws must be observed by healthcare professionals, insurers, employers, and anyone else who has access to a patient's genetic information (Kaiser Family Foundation, 2018).

The Health Insurance Portability and Accountability Act governs the administration of patient health information, including genetic information (HIPAA). HIPAA requires covered organisations to adopt reasonable and necessary administrative, physical, and technological measures to maintain the confidentiality, accuracy, and accessibility of electronic protected health information (ePHI). Before sharing genetic information to other parties, HIPAA-compliant covered organisations must get written agreement from patients (Department of Health and Human Services, n.d.).

In a separate research, Wolf et al. emphasised the need of educating patients and healthcare providers on the privacy and security risks associated with DNA sequencing (2013). The authors emphasised the need of patient permission obtained after being fully informed of the possible risks and benefits of genetic testing (Wolf et al., 2013).

According to the research, genetic sequencing raises specific security and privacy problems for the healthcare business, and that robust data security regulations and patient education are required to secure the privacy and confidentiality of sensitive genetic data (Haga et al., 2011).

Best practices for securing sensitive data:

Numerous rules and regulations aimed at protecting patient privacy and ensuring ethical genetic data use apply to the processing of sensitive genetic information. The following are some of the most important laws and regulations: HIPAA (Health Insurance Portability and Accountability Act): HIPAA is a federal act that establishes principles for the nationwide protection of patient health information (U.S. Department of Health & Human Services, n.d.).

Under HIPAA, genetic data is considered a type of protected health information (PHI), and covered organisations, such as healthcare providers and health plans, are expected to implement rules and processes to secure this data. The HIPAA Privacy Rule requires covered businesses to get patient consent before disclosing genetic information, with a few exceptions.

The European Union's General Data Protection Regulation (GDPR) - The GDPR, a data protection law, applies to all member countries of the European Union. The GDPR requires organisations to obtain express consent before collecting and using genetic data. They must also use appropriate security measures to protect sensitive information (European Commission, 2018).

General Data Protection Regulation (GDPR) of the European Union – The European Union's member nations are all subject to the GDPR, which is a rule governing data protection. Prior to collecting and utilising genetic data, organisations are required by the GDPR to get explicit consent. They also need to put the right security measures in place to safeguard this data.

Consumer Privacy Act of California (CCPA): The California Consumer Privacy Act (CCPA) provides Californians the right to know what personal information is being collected about them, the option to request that information be deleted, and the right to refuse to have that information sold. According to the CCPA, "personal information" includes genetic information (California Legislative Information, 2022).

In general, compliance with these laws and standards is critical to ensuring the responsible handling of private genetic data. Organizations that handle genetic data should engage with legal counsel on a regular basis to ensure that their data management processes are in accordance with applicable laws and regulations.

Procedures to protect data:

According to best practices, genetic data should be protected using a comprehensive approach that includes both technical and administrative security measures (GenomeWeb, 2019).

- To prevent unauthorized access, genetic data should be encrypted both in transit and at rest using industry-standard encryption techniques such as RSA or AES.
- Access controls should be implemented to ensure that only authorized individuals have access to genetic data, and password-protected systems and rigorous authentication methods can be used to achieve this.
- Data minimization is also important, and organizations should only gather and retain the bare minimum of genetic data for specific purposes.
- To ensure business continuity and disaster recovery, organizations should have policies in place for recovering genetic data in the event of a catastrophe or system failure, with regular testing and revisions of these plans.
- Additionally, employee education and awareness are crucial, and businesses should educate staff members about the importance of protecting genetic data and specific rules and regulations that must be followed.
- Data that is sensitive should be encrypted both in transit and at rest. Encryption protects data if it gets into the wrong hands and guarantees that only authorised individuals have access to it.
- Strong passwords and encryption should be used to safeguard devices carrying sensitive information, such as computers and mobile phones. Workers should also avoid leaving their gadgets in public locations unattended.
- Only secure means, such as encrypted email or secure messaging applications, should be used to exchange sensitive information.
- Workers must promptly report any security events or suspected breaches to their supervisors or the IT department. This covers instances like lost or stolen gadgets, strange emails, and illegal data access.
- Management of third-party suppliers is also important, and organizations should conduct due diligence on third-party vendors to ensure they have adequate security procedures in place to safeguard genetic information (GenomeWeb, 2019).

Organizations can reduce the risk of unauthorised access to or disclosure of genetic information by putting these best practises into practise.

Case studies:

According to a paper, healthcare data breaches may have major consequences for both patients and healthcare professionals, as two case studies demonstrate.

Data Breach at Anthem Inc.:

Anthem Inc., one of the largest health insurers in the United States, had a huge data breach in 2015 that affected around 80 million customers (Bates, 2015). Patients' personal and health information, including sensitive information like as names, birth dates, social security numbers, and medical identification numbers, were compromised as a result of the breach, possibly putting them at risk of identity theft and other fraudulent acts.

Data Breach at the NHS:

Similarly, the UK's National Health Service (NHS) had a large data breach in 2017 that affected roughly 150,000 people owing to a coding error in a software application used by the NHS (BBC News, 2017). The hack allowed unauthorised access to patient data, including names, addresses, and medical information, putting patients at risk of identity theft and other fraudulent activities.

These two case studies emphasise the importance of data security in healthcare and the necessity for healthcare professionals to be vigilant in securing sensitive data and preventing unauthorised access.

Method

Evaluating current security measures:

A thorough analysis of the organization's policies, practices, and technical infrastructure was part of the methodology used to evaluate Khupragenics' present security measures. This includes analyzing records like security policies and incident response plans and doing technical testing to find weaknesses in the organization's systems (Creswell, 2014).

This project's research technique is a hybrid of qualitative and quantitative methodologies. The qualitative technique entails conducting interviews and questionnaires to acquire insights about Khupragenics' present security measures, possible weaknesses, and opportunities for development. The quantitative technique entails conducting a security audit of Khupragenics' existing systems in order to find flaws and opportunities for improvement.

We will perform qualitative study by interviewing important stakeholders such as Khupragenics management, IT workers, and data security specialists. The interviews will be organized around a series of questions aimed to extract information about current security measures, possible weaknesses, and opportunities for improvement. We will also send questionnaires to Khupragenics workers and customers to get their thoughts on the company's security procedures and their degree of trust in the company's capacity to safeguard sensitive data (Creswell, 2014).

The National Institute of Standards and Technology (NIST) Cybersecurity Framework and the Health Insurance Portability and Accountability Act (HIPAA) Security Rule served as the foundation for the technique. These frameworks offer a methodical way to evaluate security measures and pinpoint areas that need improvement (NIST, 2018).

We will undertake a security evaluation of Khupragenics' existing systems utilizing a combination of automated tools and manual testing methodologies to accomplish the quantitative study. An examination of the company's network architecture, access restrictions, data encryption, and other security measures will be part of the security assessment. The security assessment findings will be used to identify possible vulnerabilities and areas for improvement (Penetration Testing Execution Standard, 2014).

The information gathered through interviews, surveys, and security assessments will be examined using a combination of qualitative and quantitative data analysis methodologies. Thematic analysis will be used to study qualitative data, while statistical approaches will be used to analyze quantitative data (Creswell, 2014).

Data collection Methods:

This project's data collecting methods includes both primary and secondary data sources. Interviews were conducted with important persons at Khupragenics, including executives, IT workers, and employees who manage sensitive data. Secondary data sources included scholarly literature, industry publications, and government policies pertaining to healthcare data security.

Interviews:

Key individuals at Khupragenics were interviewed to learn about the company's existing security procedures, possible vulnerabilities, and data protection strategies. Depending on the availability and preferences of the respondents, interviews were performed both in person and remotely. To maintain uniformity between interviews while providing for freedom to explore themes in more detail, a semi-structured interview method was adopted. The interviews were taped, transcribed, and examined to look for common themes and patterns.

Secondary Information Sources:

Secondary data sources included scholarly literature, industry publications, and government policies pertaining to healthcare data security. These resources were utilised to help establish the security assessment methodology and identify best practises for protecting sensitive data in healthcare. The sources were chosen based on their project relevance, quality, and dependability. These were evaluated, analysed, and synthesised to offer a thorough picture of data security in healthcare today and to highlight possible areas for improvement.

Detailed plan:

The following procedures were taken to establish the comprehensive plan for ensuring consumer confidence:

- Identifying important risks was the first step in determining the main dangers of handling private genetic data. Reviewing pertinent legislation, rules, and industry best practises were required for this.
- The next stage was to examine the security measures currently in place in Khupragenics to find places where they may be strengthened.
- Creating suggestions: To enhance the security of sensitive genetic information, a set of recommendations was created based on the study of the main risks and the state of the security measures.
- Recommendations were then ranked in order of priority according to how likely they were to affect customer confidence and how feasible it would be to implement them.
- Creating an implementation strategy: A thorough implementation strategy was created and included detailed instructions for carrying out the recommendations.
- Testing and validation: The implementation plan were afterwards examined to see if it adequately addressed the risks found and enhanced the security of private genetic data.

The procedure was based on industry-recognized frameworks including the HIPAA Security Rule and the NIST Cybersecurity Framework. These frameworks offer a methodical way to create and carry out thorough security plans.

Following are the services been used to create infrastructure:

EC2:

Elastic Compute Cloud is a cloud service from Amazon Web Service. It Provides scalable computing capability based on user needs. Users can use this service to create virtual machines with customization options for the operating system, network configuration and security rules. (Secure and Resizable Cloud Compute – Amazon EC2 – Amazon Web Services [AWS], n.d.)

WAF:

(Web Application Firewall) This service is for web security guards against common web vulnerabilities, including SQL injection, cross-site scripting (XSS) and distributed denial of service (DDOS). WAF delivers superior protection for web applications with programmable traffic filtering rules and the capacity to interface with other AWS services. (Protect Web Applications – AWS WAF – AWS, n.d.)

ROUTE53:

Amazon Route 53 is a domain name system (DNS) that offers scalable, highly available and cost-effective web service that translates domain names into IP addresses and helps route end users to internet applications. Also, it monitors the health and performance of resources by integrating health checks. (Amazon Route 53 | DNS Service | AWS, n.d.)

ELB:

Elastic Load Balancing automatically distributes incoming application traffic across multiple targets called target groups, which include EC2 instances or containers to help increase application availability and fault tolerance. There are three types of load balancers: Application Load Balancer, Network Load Balancer, and Classic Load Balancer. (Load Balancer - Amazon Elastic Load Balancer (ELB) - AWS, n.d.)

Auto Scaling:

Auto-scaling assists in dynamically scaling resources in accordance with user needs by keeping track of application performance and modifying the capacity of resources like EC2 instances, Amazon ECS containers, and other resources. Application uptime is maintained, and resource usage is optimized with the help of auto-scaling, which may be set up to react to changing circumstances and events. (App Scaling - AWS Application Auto Scaling - AWS, n.d.)

S3:

S3 (Simple Storage Service) is an object storage service that provides highly scalable, reliable, and secure storage for various data types, including files, documents, photos, and videos. For various use cases, including frequent access, infrequent access, and long-term archival, S3 offers customizable storage classes. It enables users to store data anywhere on the web and retrieve it anytime. (Cloud Object Storage – Amazon S3 – AWS, 2023)

RDS:

RDS (Relational Database Service) is simple to set up, run, and scale a relational database in the cloud. RDS provides capabilities like automated software patching, automatic backups, and straightforward resource scaling. It supports a number of well-known database engines, including MySQL, PostgreSQL, Oracle, and SQL Server. (Fully Managed Relational Database - Amazon RDS - AWS, 2023)

CloudWatch:

AWS CloudWatch is a monitoring service that gathers and tracks metrics, logs, and events from a variety of resources and applications to give users information about the performance and health of those resources and applications. Users get access to CloudWatch's alarm and notification settings, resource use and performance monitoring, and system-wide health and operational status visibility tools. (Application and Infrastructure Monitoring – Amazon CloudWatch – AWS, 2023)

SNS:

SNS (Simple Notification Service) allows messages to be sent to a large number of recipients or endpoints, including email, SMS, push notifications for mobile devices, and more. Users can establish topics, add subscribers, and send messages to those topics over a variety of protocols on SNS's highly accessible and scalable messaging platform. (Push Notification Service - Amazon Simple Notification Service (SNS) - AWS, 2023)

IAM:

IAM (Identity and Access Management) is used to manage access to AWS services and resources securely. IAM enables users to create and manage AWS users and groups, assign permissions and policies, and grant or revoke access to AWS resources. IAM provides centralized control over access and allows users to integrate with their existing on-premises identity systems. (AWS IAM | Identity and Access Management | AWS, 2023)

GuardDuty:

GuardDuty is a threat detection that continuously monitors and analyzes Amazon CloudTrail, VPC Flow Logs, and DNS Logs for suspicious activity and unauthorized conduct to help safeguard AWS accounts and workloads. GuardDuty employs anomaly detection and machine learning to find potential security issues, such as strange API calls, malicious IP addresses, and compromised instances. It then sends customers real-time notifications and actionable insights to help them deal with threats and take appropriate corrective action. (Intelligent Threat Detection - Amazon GuardDuty - AWS, 2023)

Workspaces:

Amazon Workspaces is a virtual desktop infrastructure (VDI) service that runs in the cloud and lets users manage and provision cloud-based desktops for their remote or in-house workforce. Workspaces reduce the need for physical infrastructure and maintenance while offering a secure

and scalable solution for accessing desktop programs and files from any location and on any device. Workspaces include features including user management, data encryption, and interaction with AWS Directory Service. It supports a variety of operating systems, including Windows and Linux. (Fully Managed VDI – Amazon WorkSpaces Family – AWS, 2023)

Nessus Essential:

Nessus is a popular vulnerability scanner that can detect and analyse security flaws in computer systems, networks, and web applications. It is well-known for its precision and thoroughness in detecting a wide range of vulnerabilities, including some that are notoriously difficult to detect. Nessus may be used to conduct frequent vulnerability assessments, assisting companies in identifying and mitigating possible security problems before they are exploited by bad actors (Tenable, n.d.).

Nessus can be used by Khupragenics to scan its website and web apps for vulnerabilities and potential security threats. This can assist Khupragenics in identifying and addressing security flaws before they are exploited by attackers. Nessus, for example, may be used to search for vulnerabilities like SQL injection, cross-site scripting, and weak password policies (Tenable, n.d.).

Nessus not only identifies vulnerabilities but also gives repair advice and may assist businesses in prioritising vulnerabilities based on severity and possible effect (Tenable, n.d.). This is especially valuable for Khupragenics since it allows the company to make educated judgements about which vulnerabilities to fix first and how to prioritise its security efforts.

Kali Linux:

Pen-testing, also known as penetration testing, is an important component of any security assessment, and Kali Linux is a popular operating system used by security experts for this reason. Under Kali Linux, there are various pen-testing tools that may be used to scan Khupragenics' website and Amazon services.

Nmap, a famous network scanner that may be used to find hosts and services on a network, is one such tool. It may also discover open ports and vulnerabilities on a target machine (Fyodor, 2019). Nikto, another tool, is a web server scanner that may detect vulnerabilities in online applications (CIRT, 2015).

In addition to these tools, Kali Linux comes with the Metasploit Framework, a robust penetration testing tool for exploiting vulnerabilities in systems and applications (Rapid7, n.d.). It comes with a large library of vulnerabilities and payloads for testing the security of Khupragenics' website and AWS services.

Rapid7 InsightIDR:

Rapid7 InsightIDR is a cloud-based security platform that offers an all-encompassing approach to threat detection and incident response. It includes functions like log aggregation, user and entity behaviour analytics (UEBA), and automated incident response.

Rapid7 InsightIDR scans Khupragenics' website and Amazon services using a variety of data sources such as web logs, security logs, and network traffic data. InsightIDR can discover and notify on any unusual behaviour or potential security issues by evaluating various data sources. InsightIDR, for example, may identify indications of compromise (IoCs) such as malware infections, phishing attempts, and unauthorised access attempts.

InsightIDR's enhanced threat detection capabilities, according to Rapid7, are built on machine learning and behavioural analytics, allowing it to detect and respond to threats in real-time. This is accomplished by a combination of automatic reaction activities such as quarantining infected computers or blocking malicious IP addresses, as well as user-friendly dashboards that enable security professionals to examine and remediate threats quickly and simply.

Following figure represent cloud infrastructure and workflow.

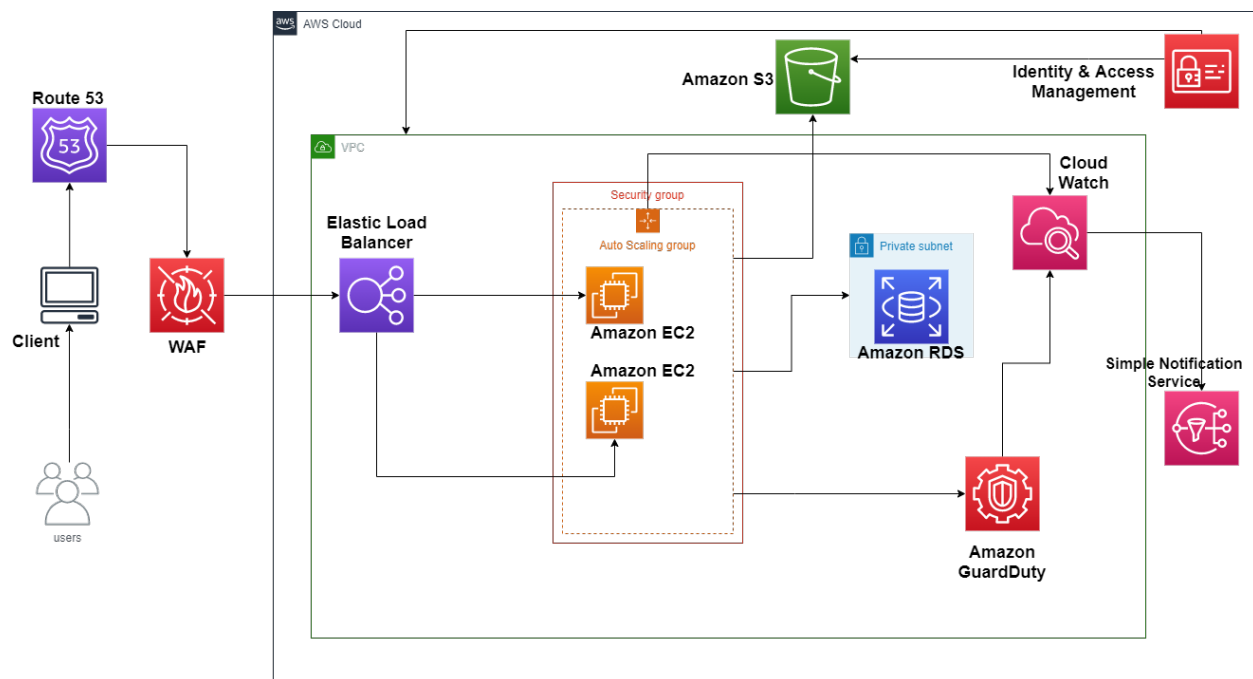


Figure 1.0

The above image is the solution architecture of cloud infrastructure. The image depicts two sides. One is client, and the other is cloud infrastructure. The workflow of the system starts from the client side. As our client has to work with sensitive information, to connect to their system, they must use only the designated client machine, which already has a virtual desktop (Amazon workspaces) installed in it. They send a request to the web server running on the cloud from that machine. Once they send the request, it will reach route53 and then redirect to the Elastic Load Balancer, but before that, there is WAF (Web application firewall). In the WAF, there is a list of the designated machine, so requests coming from that machine will only process other requests that WAF will deny.

Next, the request will be distributed to one of the running web servers (EC2) and distributed by ELB (Elastic Load Balancer). The web server machine is part of the Auto Scaling Group, which

means that when there are more incoming requests, ASG will add a new web server that will connect to ELB. So that ELB can distribute requests among those running instances.

Again, these web servers have their own security rule configured by the admin and can be changeable as per client requirements. Now, these web servers run a web application with SQL database. In the cloud, it is an RDS server (Database Server) which is private and encrypted. As well as for file storage, we have S3(Simple Storage Service), which is also secured with encryption.

As MSSP, monitoring and vulnerability assessment are required to secure the system. Therefore, we have implemented a service called GuardDuty, also called the security dashboard, in our cloud infrastructure. GuardDuty provides a dashboard that represents assessment and monitoring data. Additionally, there is CloudWatch, which will keep logs of activity happening on the cloud that can later be used to track issues. Lastly, there is a service called simple notification service (SNS) that will send a notification based on the threshold set by the administrator. So, if anything happens in the system, it will send an email or message to the designated person about the incident. So, it's all about how the systems work and the cloud infrastructure.

Security Policy:

The purpose of physical security regulations is to safeguard a company's tangible assets, such as its physical structures and machinery, which includes computers and other IT hardware. Policies governing data security shield intellectual property from expensive occurrences like data breaches and data leaks. Functions served by security policies like:

1. Directs how technical controls are implemented:
The aims and expectations of senior management with regard to security are outlined in a security policy, which does not offer detailed low-level technical guidance. The security or IT teams will then need to turn these intentions into precise technological steps.
2. Sets clear expectations:
Without a security policy, each employee or user will be left to use his or her own discretion to determine what is and is not acceptable. When different personnel use various standards, this can go horribly wrong. So, a security policy should specify exactly how compliance will be checked and enforced.
3. Contributes to the fulfilment of legal and compliance criteria:
Regulations and standards like PCI-DSS, ISO 27001, and SOC2 as well as laws like HIPAA and Sarbanes-Oxley all call for the documentation of security policies. Even when it isn't stated expressly, a security policy is frequently a practical necessity when developing a plan to satisfy the ever-increasing security and data privacy regulations.
4. Enhances organisational performance and aids in achieving business goals:
An organization's effectiveness can be increased with a sound security policy. Its rules ensure that everyone is on the same page, prevent effort duplication, and offer consistency in monitoring and enforcing compliance. The timing and authority of granting policy exceptions should be made very clear in security policies.

Findings

Security Assessment:

The following are the findings of the security assessment:

To identify possible weaknesses in Khupragenics' systems and methods for managing sensitive data, a thorough security evaluation was performed. The evaluation included both technical and non-technical approaches, such as penetration testing, vulnerability scanning, key stakeholder interviews, and document review.

Many areas of concern were found during the review, including:

- Lack of employee training on data security best practices.
- Insufficient access controls for sensitive data.
- Inadequate network segmentation.
- Outdated software and hardware.

Based on these data, numerous recommendations for improving Khupragenics' security procedures were identified. Implementation of regular employee training on data security best practices

- Implementation of regular employee training on data security best practices.
- Upgrading access controls for sensitive data.
- Implementing proper network segmentation.
- Regular updates to software and hardware to ensure security patches and bug fixes are applied.

Identification of Vulnerabilities:

During our security audit, we discovered many possible flaws in Khupragenics' existing security measures. These flaws may jeopardise the confidentiality, integrity, or availability of critical data, putting the firm and its customers at risk of data breaches or other security events. We divided the vulnerabilities we discovered into three categories: physical security, network security, and user security.

Physical security:

Physical security refers to the mechanisms in place to secure physical assets from illegal access, theft, or damage, such as buildings, equipment, and storage media. We discovered the following possible flaws in Khupragenics' physical security:

- Insufficient access controls: No access controls, such as swipe cards or biometric scanners, were in place to restrict admission to the server room or other places where sensitive data is held.
- Inadequate facility design: The server room was positioned in an area of the building that was poorly planned, making it subject to natural risks such as floods or fires.
- Inadequate surveillance: There were no security cameras in the server room or other places where sensitive data is housed, making illegal access difficult to detect.

Network Security:

The mechanisms in place to secure data in transit between computers and devices on a network are referred to as network security. We discovered the following possible flaws in Khupragenics' network security:

- Workers were using weak passwords that were easy to guess or crack, allowing attackers to obtain unauthorised access to the network.
- Unsecured wireless network: Because the company's wireless network was not encrypted, attackers could easily intercept and eavesdrop on network communications.
- Unpatched software: The corporation was utilising outdated software on its servers, which might have known security flaws that attackers could exploit.

User Security:

User security refers to the safeguards in place to guarantee that users are permitted to access data and that they use it appropriately and securely. We discovered the following possible flaws in Khupragenics' user security:

- Workers have not undergone any official security awareness training, which might leave them exposed to phishing assaults or other social engineering approaches.
- Workers had free access to sensitive data, making it impossible to track who was accessing it and for what reason.
- Workers were using the same passwords for many accounts, which may lead to a chain reaction of security breaches if one account is stolen.

Recommendations:

To address the possible risks highlighted in our evaluation, we propose that Khupragenics adopt the following measures:

- Implement access controls, such as swipe cards or biometric scanners, to limit access to the server room and other places containing sensitive data.
- Relocate the server room to a more secure part of the building or install environmental controls like fire suppression systems or waterproofing.
- Put security cameras in the server room and other rooms where critical data is kept.
- Establish a password policy that compels workers to use strong passwords and to update them on a regular basis.
- To prevent illegal access and eavesdropping, encrypt the wireless network.
- Patching and software upgrades should be performed on a regular basis to keep software up to date.
- All personnel should get security awareness training to assist them recognise and respond to possible security risks.
- Establish access restrictions and audit trails to keep track of who is accessing sensitive data and why.

Incident management standards:

Purpose:

This standard's objective is to create the policies and procedures for Khupragenics' management of cybersecurity incidents. This standard, which is based on the NIST Computer Security Incident Handling Guide, aims to give incident management an organised and unified approach.

Scope:

Those who have access to Khupragenics' systems, networks, and data fall under the scope of this standard, including all employees, independent contractors, and third-party vendors.

Standard:

- Preparation: Khupragenics will set up and maintain an incident response team made up of representatives from the management, IT, legal, and other pertinent departments. Plans, protocols, and communication channels for responding to incidents shall be created and maintained by the incident response team. In order to practise the incident response procedure, the team will also engage in frequent training and exercises.
- Identification: Upon becoming aware of any suspicious behaviour or cybersecurity problem, all employees, independent contractors, and third-party vendors are required to immediately notify the designated IT security team. The IT security team will start the incident response procedure after determining whether the incident fits the requirements for a cybersecurity incident.
- Containment: The IT security team will act right away to stop the incident's spread and to confine it. This can entail shutting down accounts, limiting network access, or isolating impacted systems. The team will also keep track of what was done and store any evidence for further review.
- Analysis: The incident will be thoroughly investigated by the IT security team to ascertain its root cause, extent, and effects. This can entail gathering and studying logs, network activity, and other pertinent data. In accordance with the seriousness of the occurrence, the team will also prioritise the reaction and evaluate the amount of danger.
- Recovery: The IT security team will create and implement a recovery plan to resume regular operations when the issue has been eliminated. Before returning systems to normal function, this could involve testing them and ensuring data integrity. The team will also keep a record of the steps taken and any alterations made to stop similar situations from happening again.
- Lessons Learned: To find areas for improvement and put remedial measures in place, the IT security team will perform a post-incident study. Analyses of the incident response procedure, the efficacy of the response strategy, and any lessons learned should all be included in the review. Based on the results of the review, the team will also revise the incident response plans and protocols.
- Enforcement- Failure to abide by this standard may result in disciplinary action, including but not limited to termination of employment, contract, or legal action.

Vulnerability management standards:

Purpose:

This Vulnerability Management Standard sets forth the procedure for locating, evaluating, and addressing vulnerabilities in Khupragenics' information systems to safeguard them from security risks.

Scope:

These standard covers all of Khupragenics' information systems and technologies, including but not restricted to servers, workstations, laptops, and mobile devices, as well as network hardware.

Procedures

- Identification of Vulnerabilities: To find flaws in its information systems, Khupragenics will employ automated vulnerability scanning techniques. The IT staff will run the tools on a regular basis and evaluate the outcomes.
- Vulnerability Evaluation: The IT team will evaluate the potential effect and likelihood of exploitation after identifying a vulnerability. The value of the asset and the risk presented by the vulnerability will both be considered in the evaluation.
- Repair of Vulnerabilities: Khupragenics will create and carry out a remediation strategy to fix a vulnerability after it is identified and assessed. Based on their risk and potential impact, vulnerabilities will be prioritised in the remediation plan. The cleanup procedure will be monitored and recorded by the IT staff.
- Verification of Vulnerabilities: The IT team will confirm that a vulnerability has been appropriately mitigated when it has been remedied. To make sure the vulnerability has been effectively fixed, vulnerability scans will need to be repeated.
- Reporting Vulnerabilities: Khupragenics will keep track of all vulnerabilities that have been found, evaluated, and fixed. The date of discovery, the type of vulnerability, the asset impacted, the remediation plan, and the date the vulnerability was fixed are all included in the record.

Responsibilities

This Vulnerability Management Standard shall be implemented and maintained by the IT staff. All vulnerabilities found by any personnel, including independent contractors, must be reported to the IT department.

Compliance

Discipline, up to and including termination of employment or contract, may follow non-compliance with this Vulnerability Management Standard.

Reviewing and Revising

To make sure that it continues to be useful and pertinent to the needs of the business, this Vulnerability Management Standard will be reviewed and updated annually, or as necessary.

Layout

Divided into three modules – Front-end, back-end & Security.

Front-End – We used below technologies from AWS as part of our infrastructure.

VDI (AWS Workspaces) – When client login into his local machine he will run a client application called Workspaces. From that, he will login into a virtual desktop or VDI which is hosted into cloud. This machine is based on windows 10 server with hard disk encrypted.

Only authorized users can login to the workspaces as we have designed this with a custom registration code. Using that code and a unique link on user's email, he will create a password for login which helps in security from very first step.

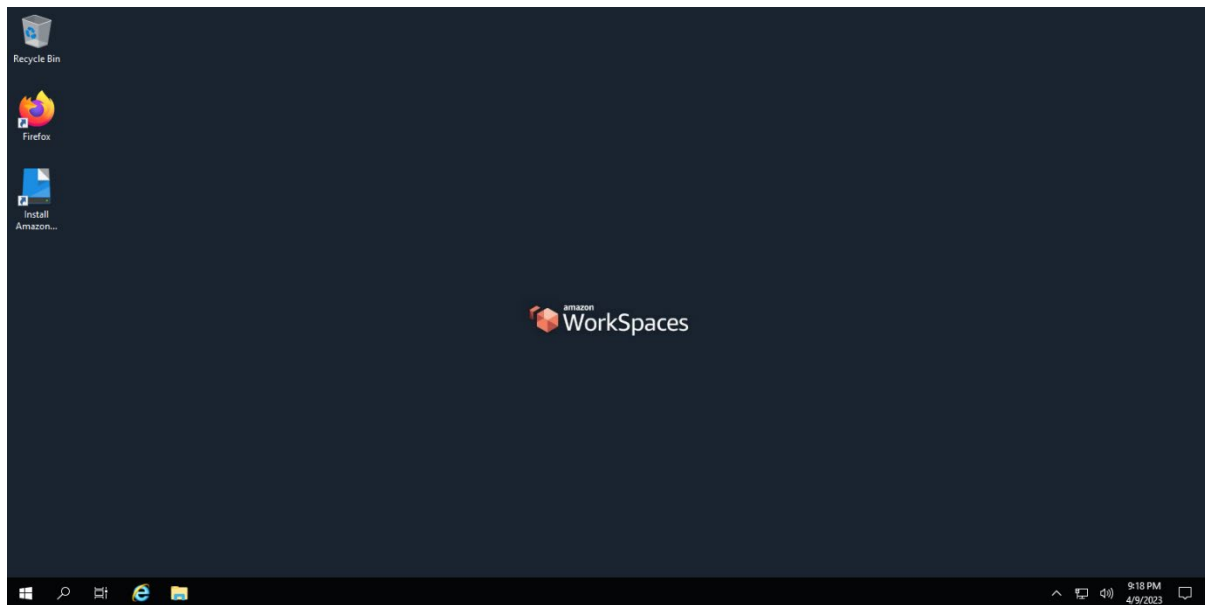


Figure 2.0

After logging into workspace machine the client will login using our custom domain www.clientkgenics.cloud which is purchased on hostinger.com. We created a custom policy which will allow client to use only www.clientkgenics.cloud.

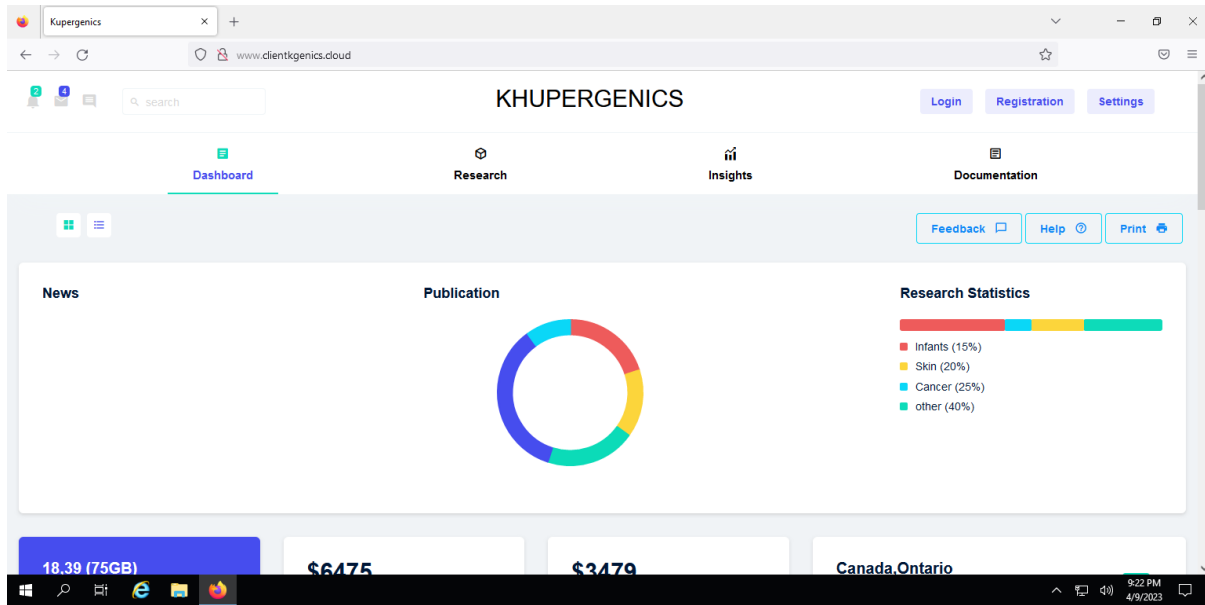


Figure 2.1

Back-end – Below are all the technologies & tools used at the back-end side.

DNS (Route 53) – Our custom domain www.clientkgenics.cloud is registered on hostinger.com and this domain is hosted on AWS route 53.

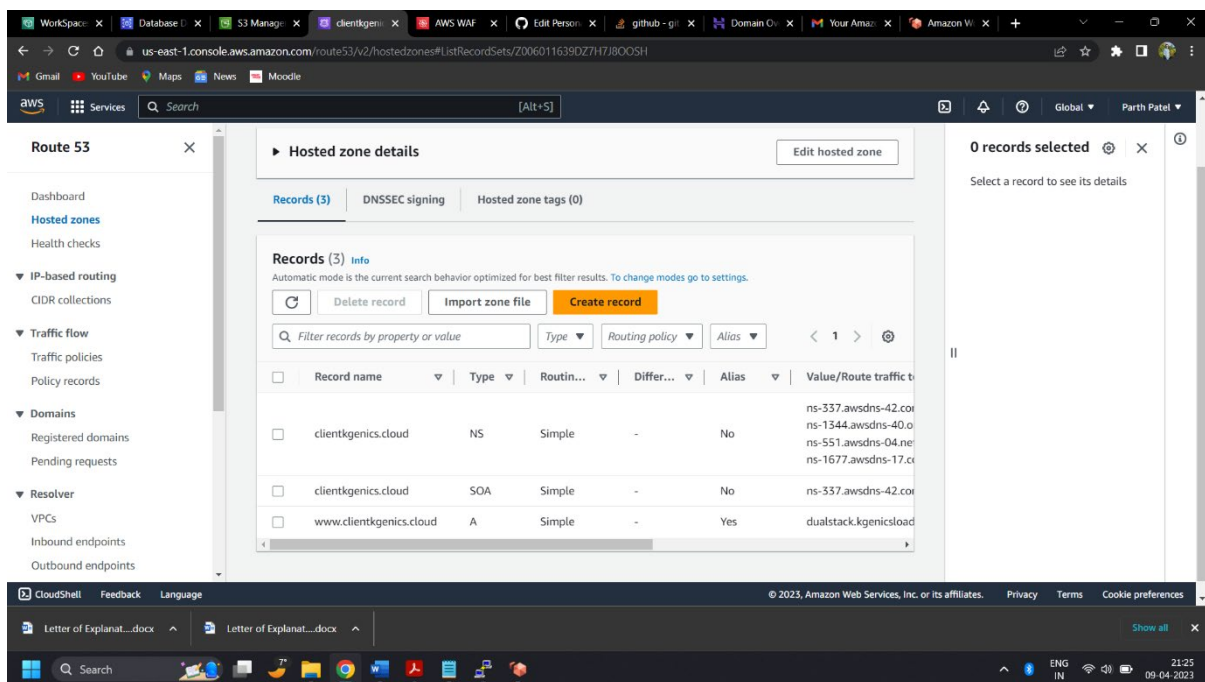


Figure 2.2

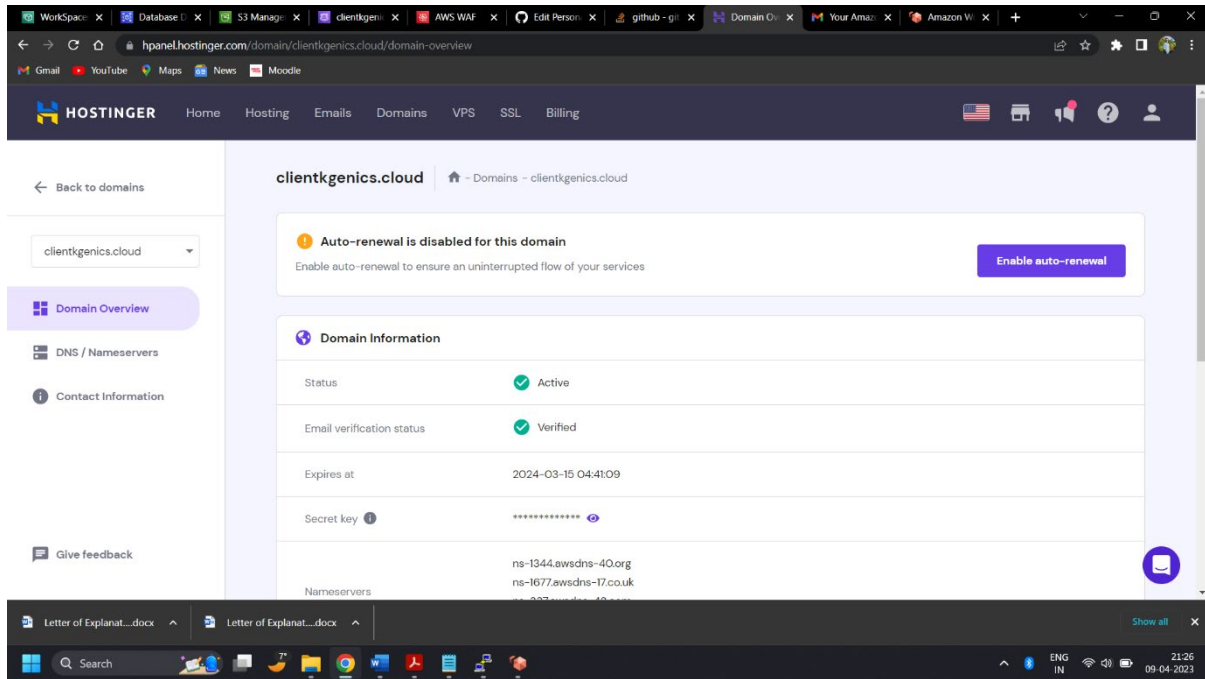


Figure 2.3

<https://hpanel.hostinger.com/domain/clientkgenics.cloud/domain-overview>

Application Firewall (WAF) – Web app firewall from AWS helped achieving anonymous traffic from the internet using custom rules which allows only configured IP addresses of the machines to access the “www.clientkgenics.cloud”. Also, WAF is configured to protect from SQL ejection & DDOS attacks.

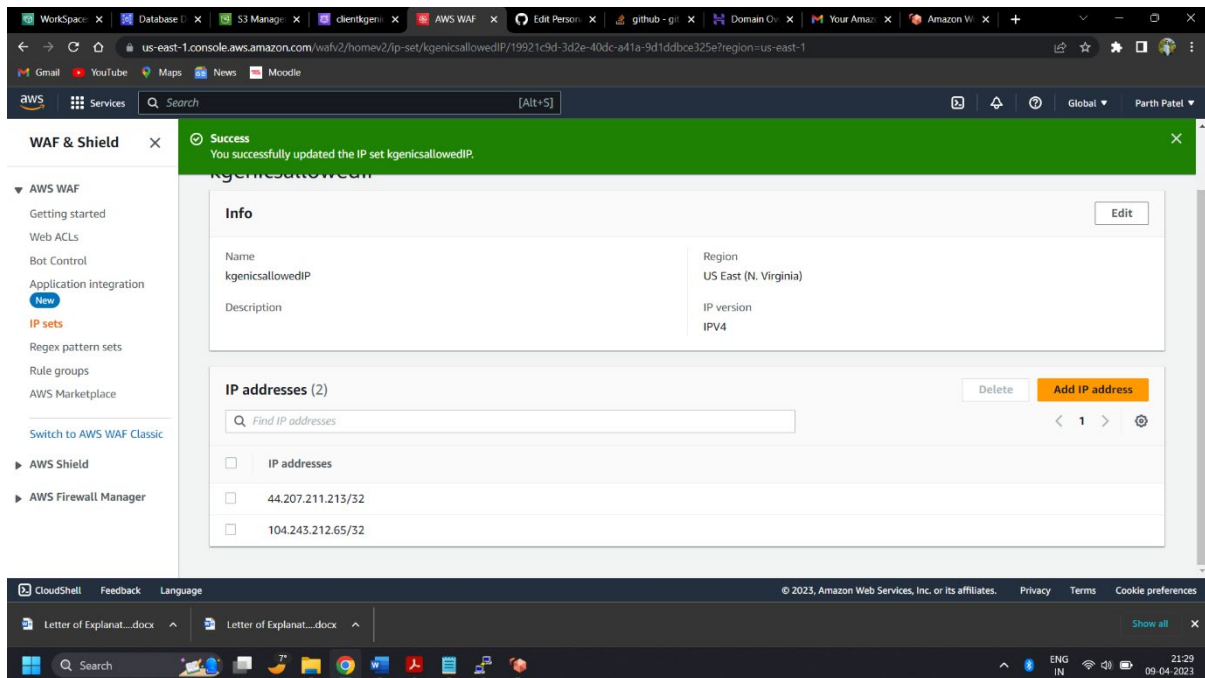


Figure 2.4

Traffic Management (Load Balancer) –Client’s Web server is hosted under EC2 machined from AWS and it requires more than one web server to provide better accessibility and speed to the clients. So, whenever more clients access the application which means load increases. By using Load balancer, it will automatically redirect traffic to the less occupied web server. We configured minimum 2 machines into multi-AZ model which helps in high availability (99.99%).

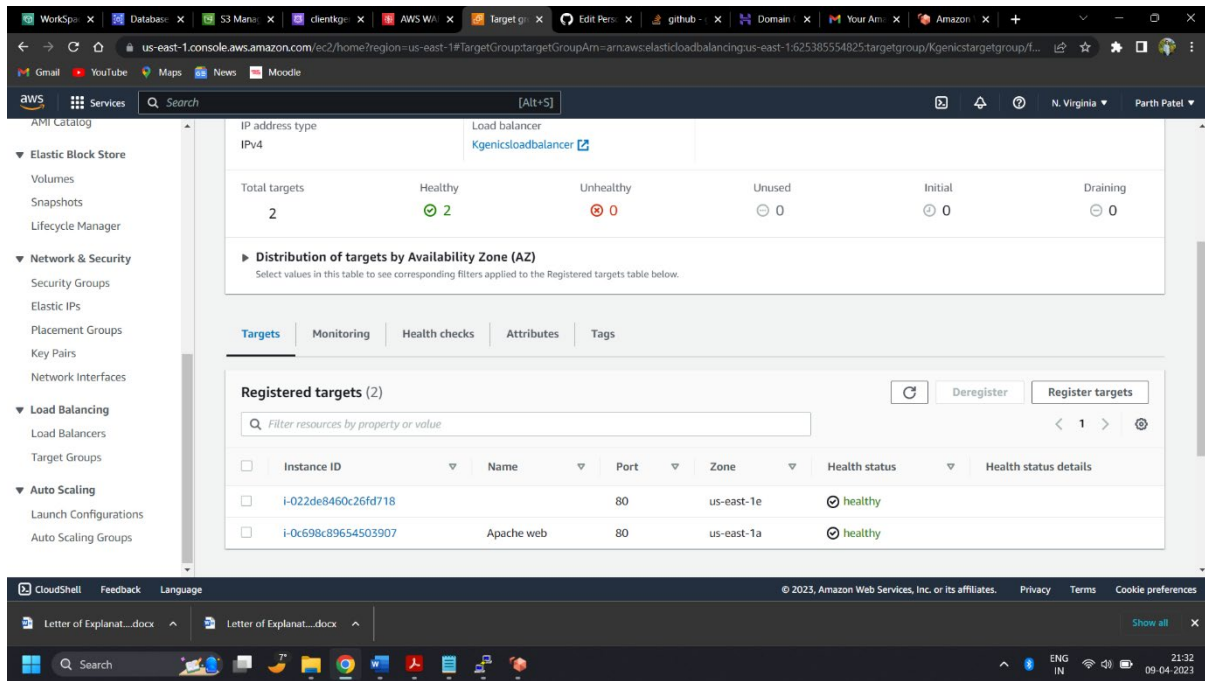


Figure 2.5

VPN (AWS VPC) – In this infrastructure AWS’s Virtual private compute service plays a huge role to provide better security. We kept most of the AWS resources into a isolated private network which is not directly accessible over the internet.

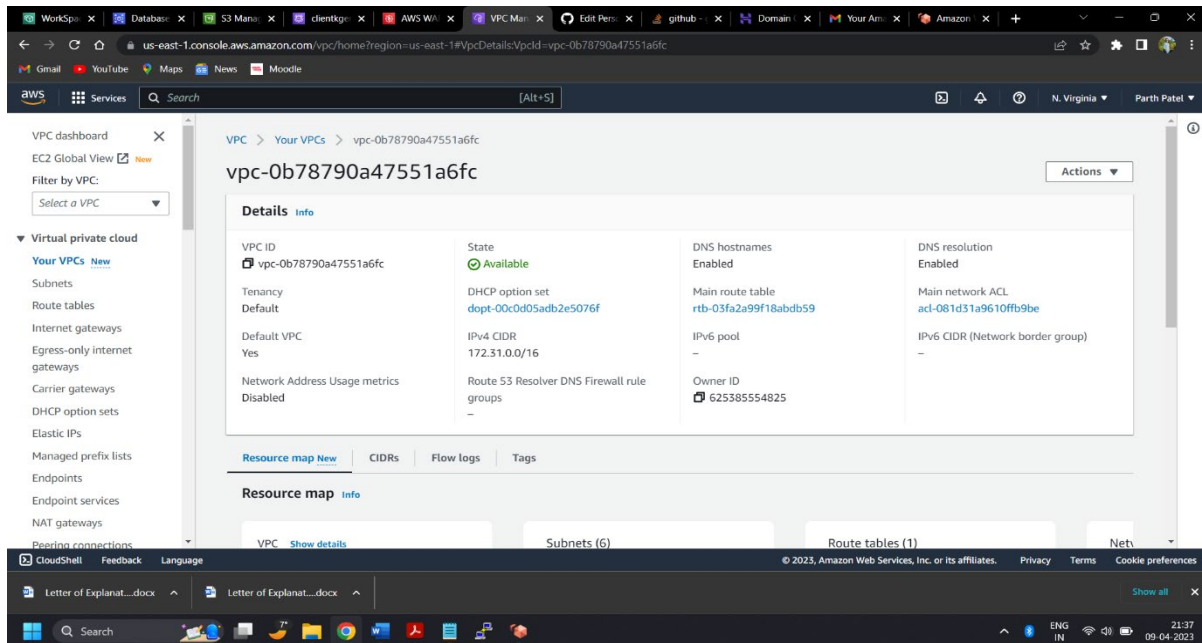


Figure 2.6

Database Server (RDS) – We used AWS RDS(Relational database services) as our database server to store the patients information into tables.

Used Multi-AZ deployment to deploy DB server in more than one availability zone, so that high availability is achieved for our client. Our DB server is hosted into private subnet so that it will not be accessible over the internet by hackers.

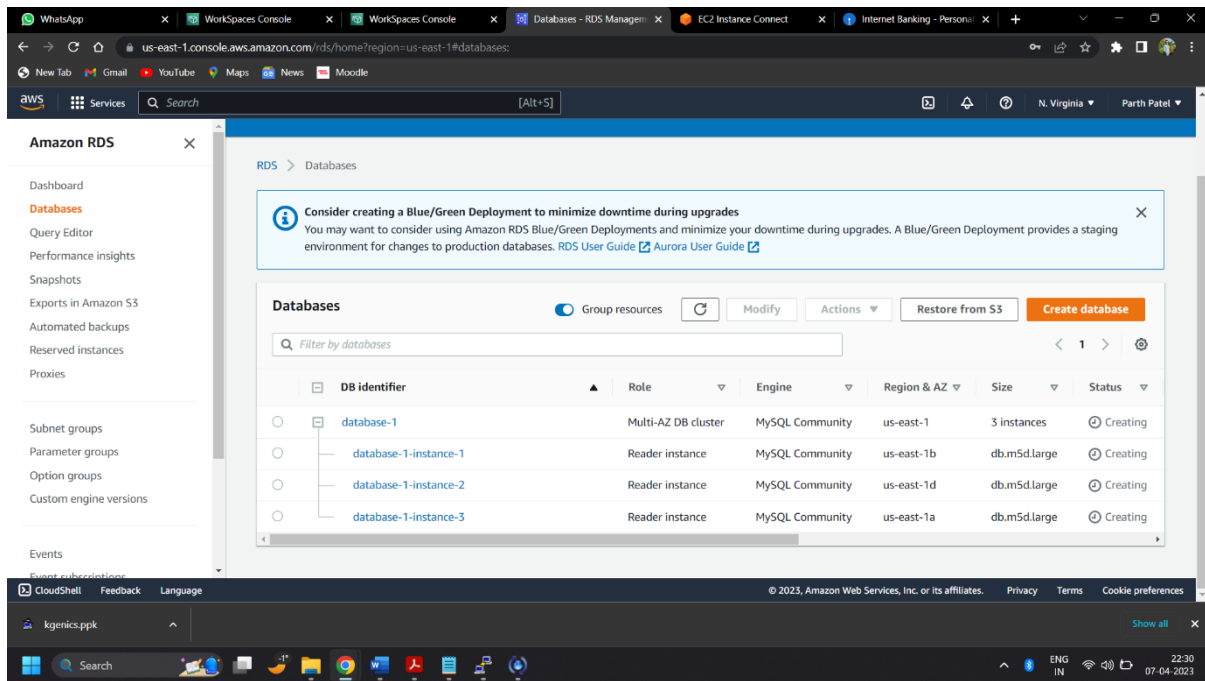


Figure 2.7

Connecting to the Database server –

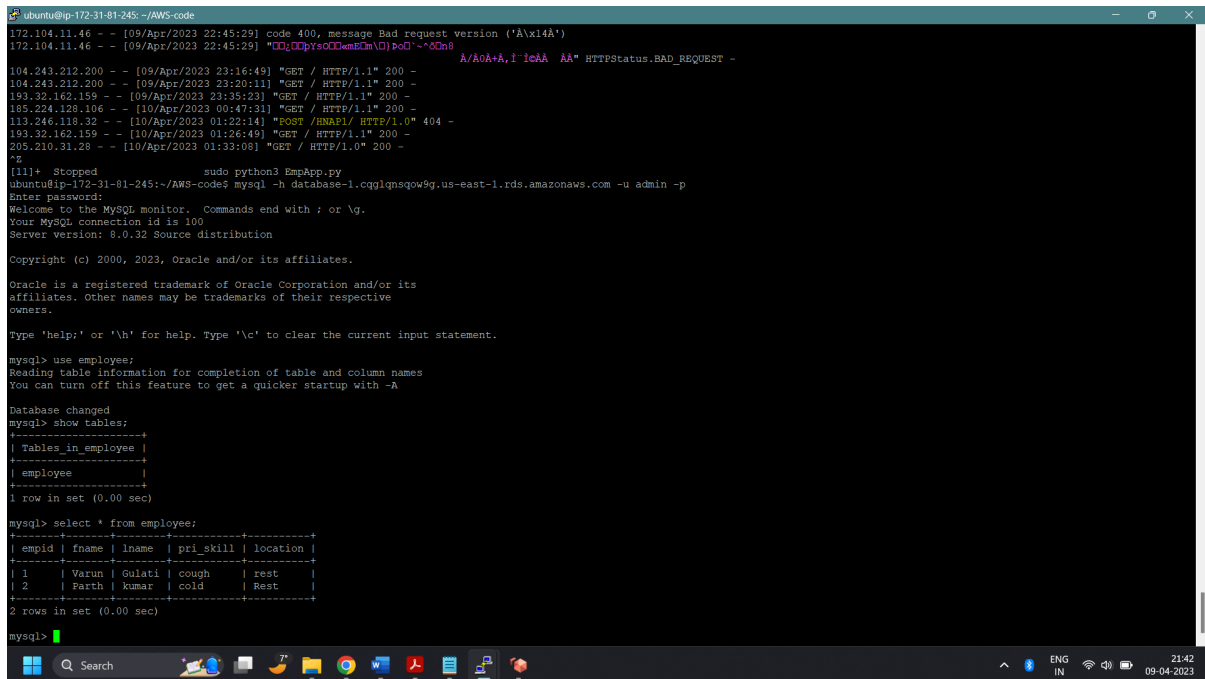


Figure 2.8

Object Storage(S3) – We configured AWS simple storage service to store patients reports as objects in buckets. This storage was made private & encrypted. Also, this is configured in multiple availability zones for backup & high availabilty of the data.

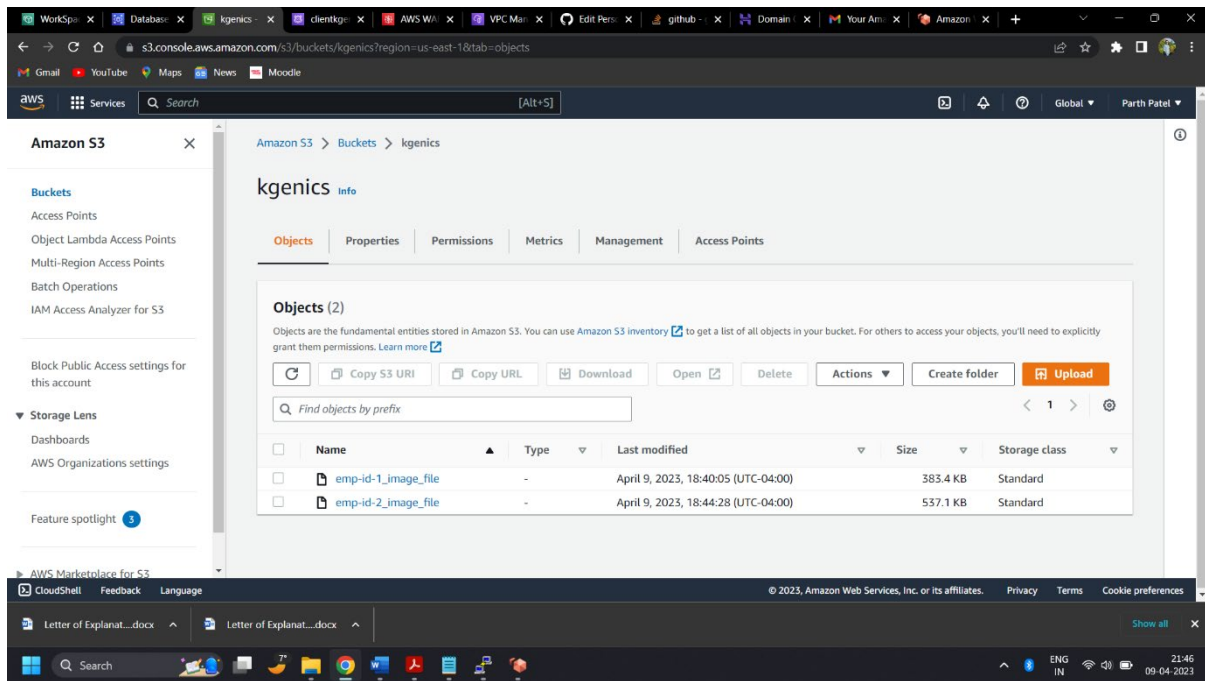


Figure 2.9

Web server (Ec2 Machines) – We created virtual machines with ubuntu installed on them for hosting our web server using “Apache web server”. This web servers are deployed into multiple availability zones for high availability.

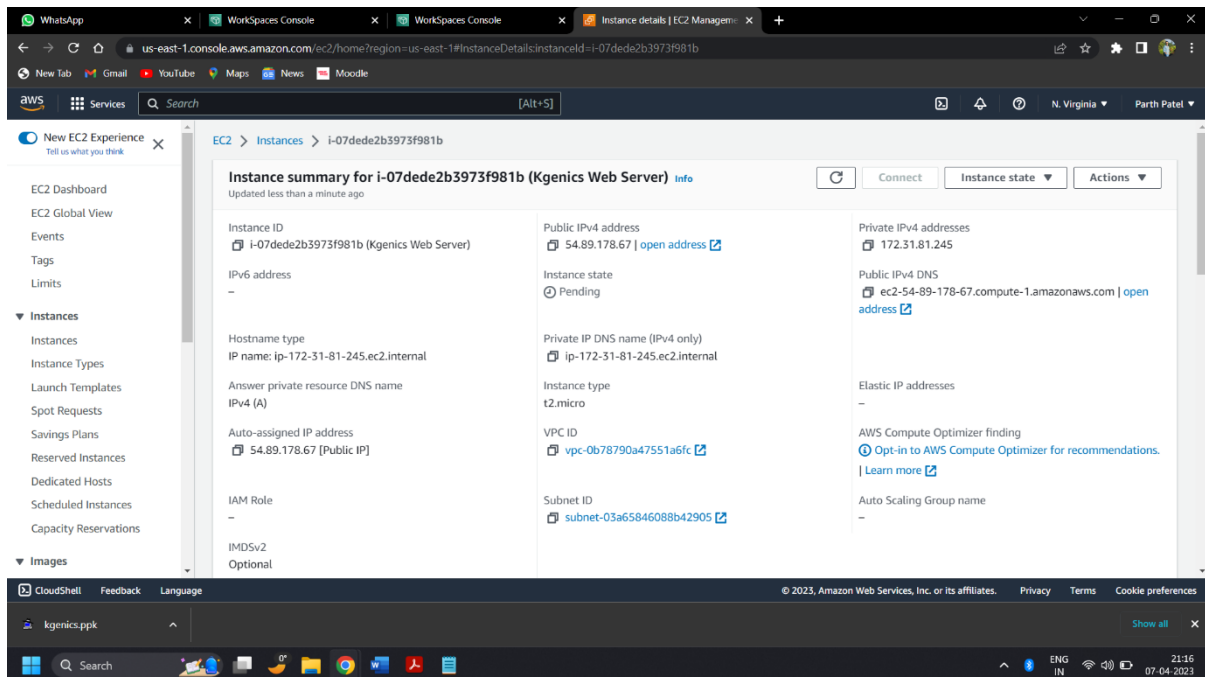


Figure 3.0

Running virtual machine –

```
root@ip-172-31-94-204:/var/www/html# cd ..
root@ip-172-31-94-204:/var/www/html# systemctl status apache2
● apache2.service - The Apache HTTP Server
   Loaded: loaded (/lib/systemd/system/apache2.service; enabled; vendor preset: enabled)
   Active: active (running) since Sun 2023-04-09 20:30:31 UTC; 5h 10min ago
     Docs: https://httpd.apache.org/docs/2.4/
   Process: 2389 ExecStart=/usr/sbin/apachectl start (code=exited, status=0/SUCCESS)
    Main PID: 2393 (apache2)
       Tasks: 55 (limit: 1141)
      Memory: 10.0M
         CPU: 1.782s
    OGroup: /system.slice/apache2.service
            └─ 2393 /usr/sbin/apache2 -k start
              2394 /usr/sbin/apache2 -k start
              2395 /usr/sbin/apache2 -k start

Apr 09 20:30:31 ip-172-31-94-204 systemd[1]: apache2.service: Deactivated successfully.
Apr 09 20:30:31 ip-172-31-94-204 systemd[1]: Stopped The Apache HTTP Server.
Apr 09 20:30:31 ip-172-31-94-204 systemd[1]: Starting The Apache HTTP Server...
Apr 09 20:30:31 ip-172-31-94-204 systemd[1]: Started The Apache HTTP Server.
root@ip-172-31-94-204:/var/www/html#
```

Figure 3.1

Assigned a fixed public IP address using AWS Elastic IP's.

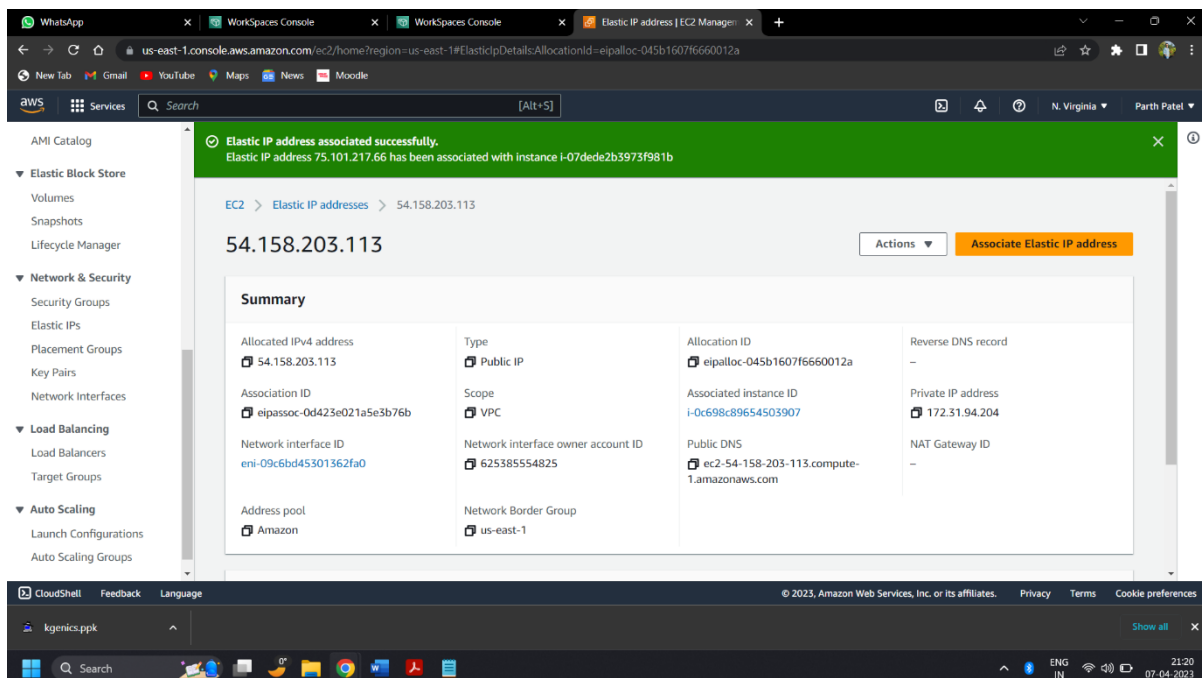


Figure 3.2

Autoscaling – Autoscaling is enabled with at least 1 machine available all the time and if demand increases then it can automatically create up to 4 web servers. In case any web server is down due to hardware/software or any other reasons, it is configured in a way that it will automatically replace that machine with a newly created machine.

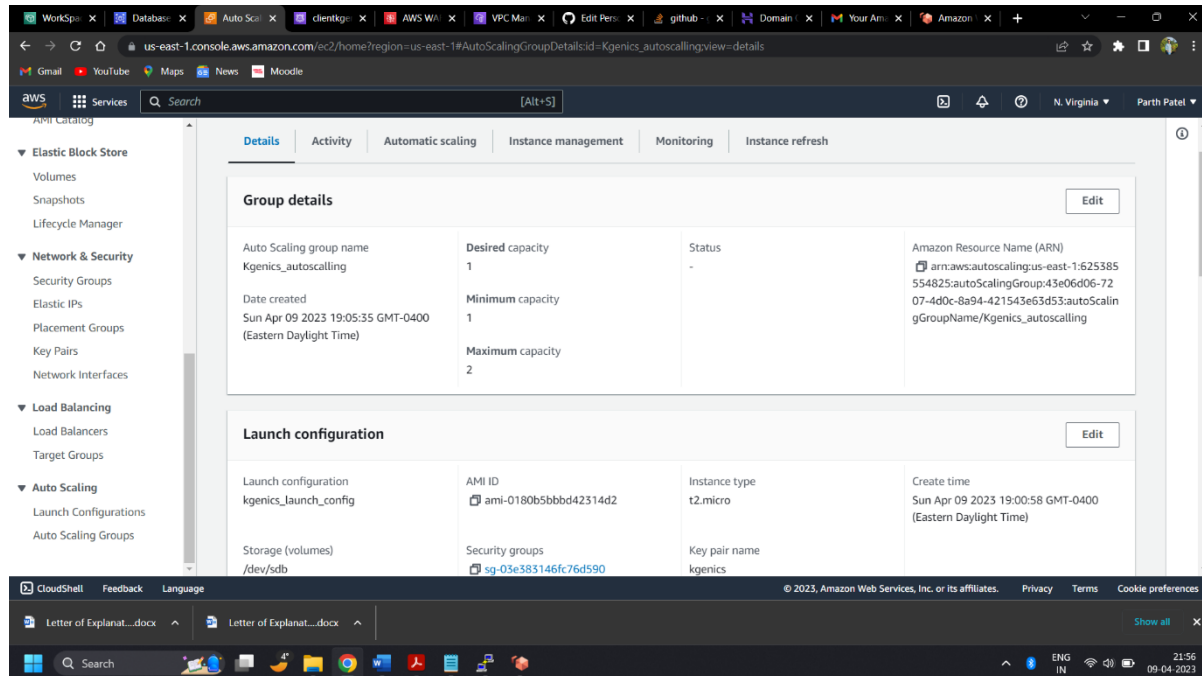


Figure 3.3

Notification services (SNS) – Using AWS simple notification services, a client or system administrator gets notifications on phones and emails quickly if anything goes bad on the back-end side.

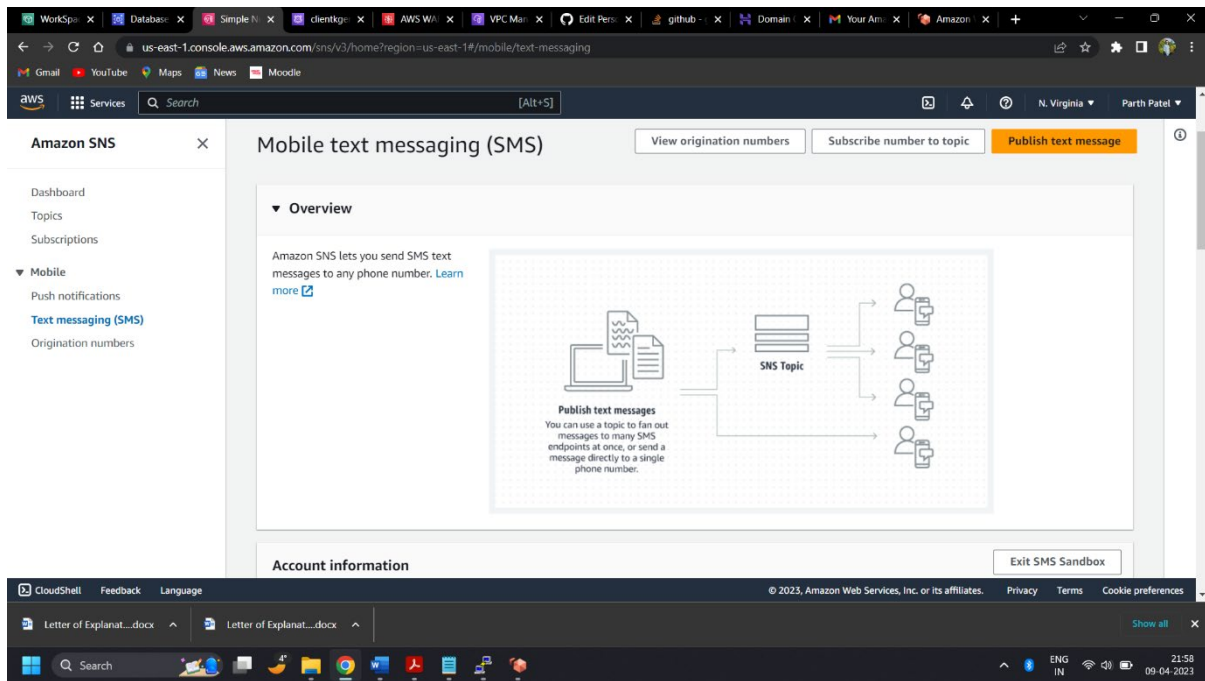


Figure 3.4

Infrastructure monitoring (Cloud watch)- Cloud watch continuously logs almost everything into log files. We enabled cloud watch on RDS server and it sends alarms quickly if anything suspicious activity gets logged.

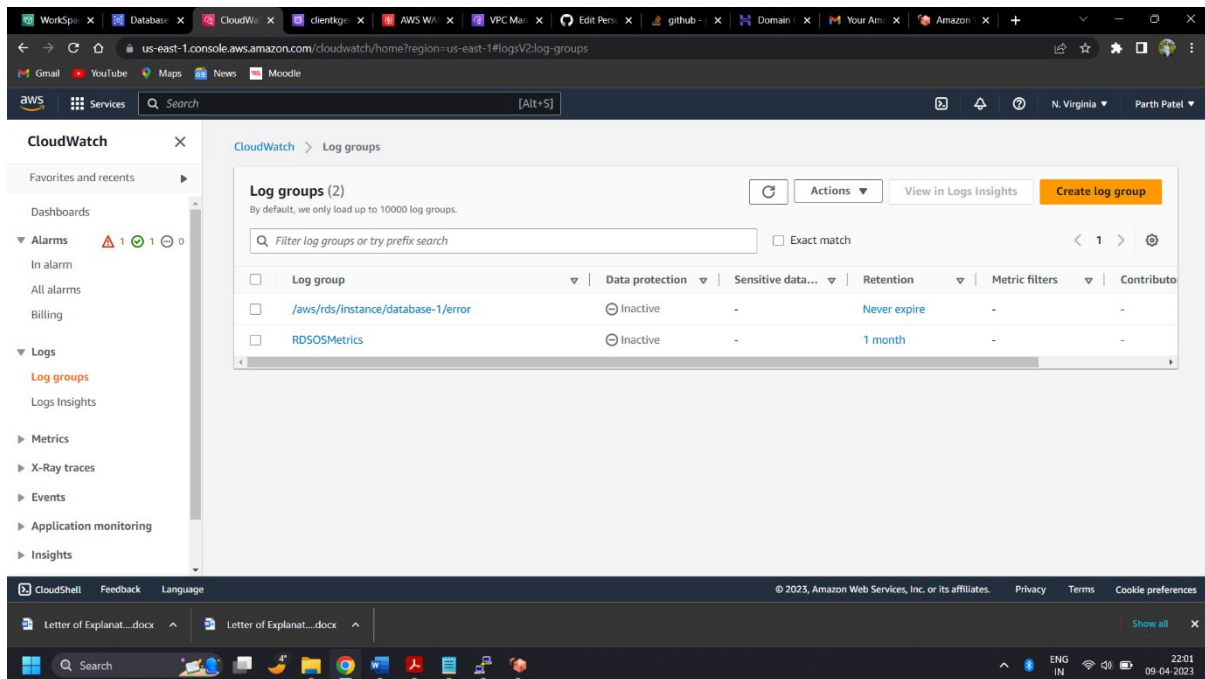


Figure 3.5

Security scanning tool (Nessus Essential):

Nessus Essential will use to scan and find vulnerabilities on web page and cloud environments. This tool allows to scan broad range of services and find any vulnerability that impact on Khupragenics infrastructure.

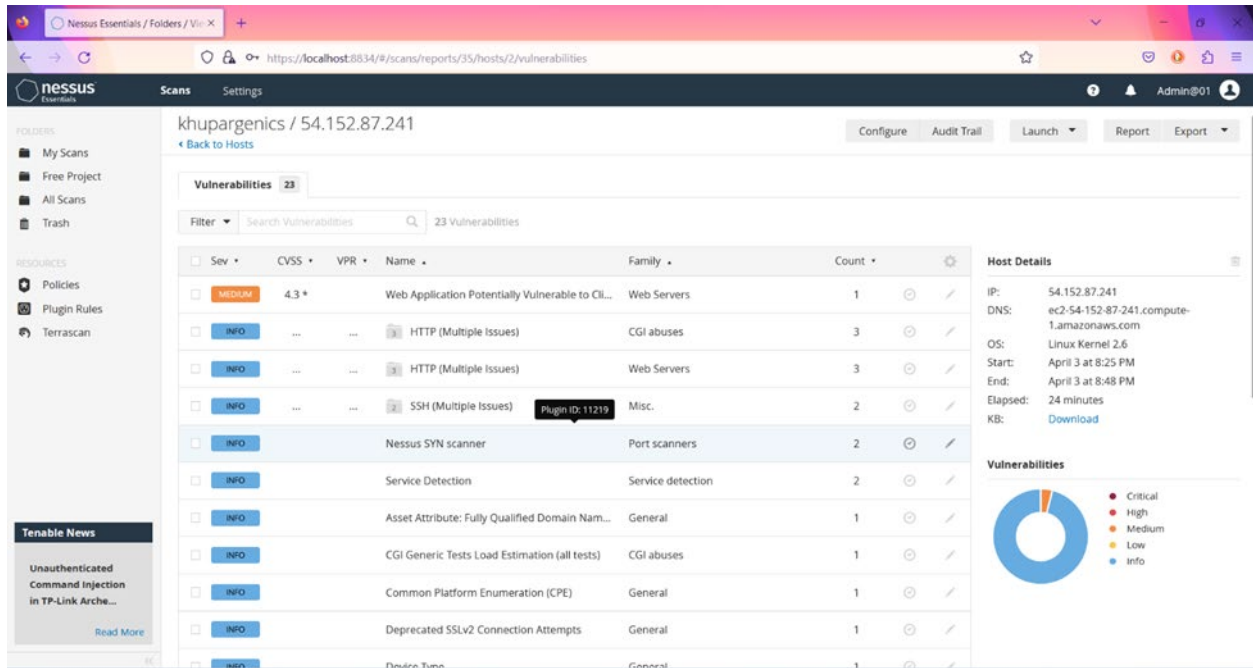


Figure 4.0

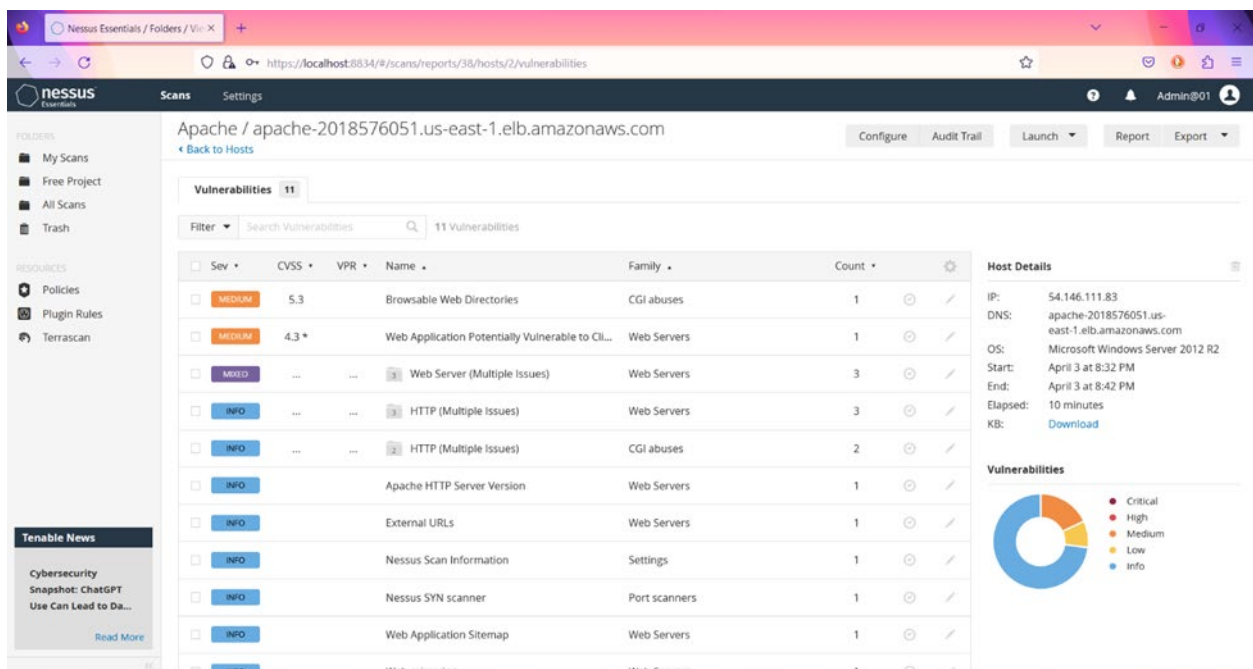
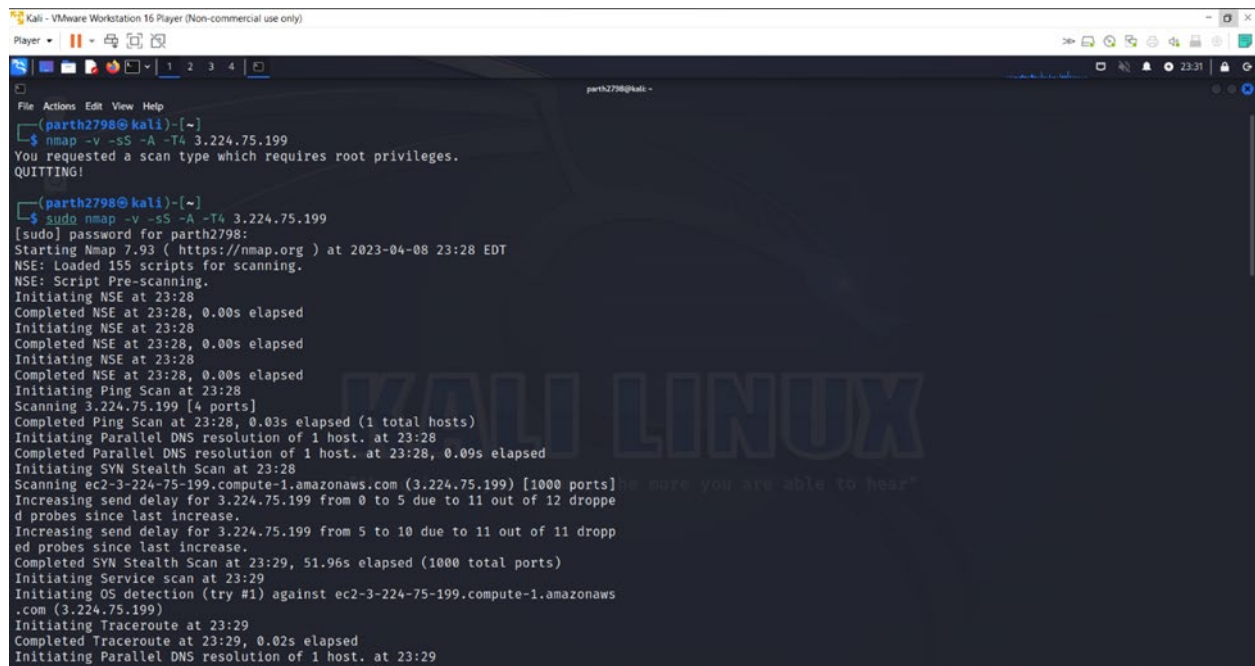


Figure 4.1

Kali Linux:

This tool is most widely used to scan, find and pen-test on any computer and we used here for pen-testing khupragenics current environment and find an loophole on system.



```
Kali - VMware Workstation 15 Player (Non-commercial use only)
Player
File Actions Edit View Help
parth2798@kali: ~
$ nmap -v -sS -A -T4 3.224.75.199
You requested a scan type which requires root privileges.
QUITTING!

(parth2798@kali)~
$ sudo nmap -v -sS -A -T4 3.224.75.199
[sudo] password for parth2798:
Starting Nmap 7.93 ( https://nmap.org ) at 2023-04-08 23:28 EDT
NSE: Loaded 195 scripts for scanning.
NSE: Script Pre-scanning.
Initiating NSE at 23:28
Completed NSE at 23:28, 0.00s elapsed
Initiating NSE at 23:28
Completed NSE at 23:28, 0.00s elapsed
Initiating NSE at 23:28
Completed NSE at 23:28, 0.00s elapsed
Initiating Ping Scan at 23:28
Scanning 3.224.75.199 [4 ports]
Completed Ping Scan at 23:28, 0.03s elapsed (1 total hosts)
Initiating Parallel DNS resolution of 1 host. at 23:28
Completed Parallel DNS resolution of 1 host. at 23:28, 0.09s elapsed
Initiating SYN Stealth Scan at 23:28
Scanning ec2-3-224-75-199.compute-1.amazonaws.com (3.224.75.199) [1000 ports]
Increasing send delay for 3.224.75.199 from 0 to 5 due to 11 out of 12 dropped probes since last increase.
Increasing send delay for 3.224.75.199 from 5 to 10 due to 11 out of 11 dropped probes since last increase.
Completed SYN Stealth Scan at 23:29, 51.96s elapsed (1000 total ports)
Initiating Service scan at 23:29
Initiating OS detection (try #1) against ec2-3-224-75-199.compute-1.amazonaws.com (3.224.75.199)
Initiating Traceroute at 23:29
Completed Traceroute at 23:29, 0.02s elapsed
Initiating Parallel DNS resolution of 1 host. at 23:29
```

Figure 4.2



```
Initiating NSE at 23:29
Completed NSE at 23:29, 0.00s elapsed
Nmap scan report for ec2-3-224-75-199.compute-1.amazonaws.com (3.224.75.199)
Host is up (0.0091s latency).
All 1000 scanned ports on ec2-3-224-75-199.compute-1.amazonaws.com (3.224.75.199) are in ignored states.
Not shown: 1000 filtered tcp ports (no-response)
Warning: OSScan results may be unreliable because we could not find at least 1 open and 1 closed port
OS details: Actiontec MI424WR-GEN3I WAP, DD-WRT v24-sp2 (Linux 2.4.37), Linux 3.2, Linux 4.4, Microsoft Windows XP SP3, Microsoft Windows XP SP3 or Windows s 7 or Windows Server 2012, VMware Player virtual NAT device
Network Distance: 2 hops

TRACEROUTE (using port 80/tcp)
HOP RTT ADDRESS
1 0.27 ms 192.168.19.2
2 0.29 ms ec2-3-224-75-199.compute-1.amazonaws.com (3.224.75.199)

NSE: Script Post-scanning.
Initiating NSE at 23:29
Completed NSE at 23:29, 0.00s elapsed
Initiating NSE at 23:29
Completed NSE at 23:29, 0.00s elapsed
Initiating NSE at 23:29
Completed NSE at 23:29, 0.00s elapsed
Read data files from: /usr/bin/./share/nmap
OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 60.58 seconds
Raw packets sent: 2073 (93.228KB) | Rcvd: 296 (11.868KB)

(parth2798@kali)~
$
```

Figure 4.3

Discussion:

Interpretation of Findings:

The research of Khupragenics' possible information security risks highlighted numerous areas that require attention to protect the confidentiality, integrity, and availability of sensitive data. According to the findings, Khupragenics may face a threat from both foreign and internal sources. External dangers include cyber-attacks, phishing assaults, and social engineering, while internal hazards include workers or third-party providers gaining illegal access to critical data.

Additionally, the vulnerability assessment revealed that Khupragenics must deploy security measures to defend itself against malware, ransomware, and other dangerous software. To reduce vulnerabilities, the organisation should also guarantee that its software and systems are frequently updated and patched. Another major worry for Khupragenics is the security of its cloud-based infrastructure. To prevent unwanted access, the organisation should establish stringent access restrictions, multi-factor authentication, and data encryption.

Furthermore, the evaluation highlighted that Khupragenics has to build a comprehensive incident response strategy in order to resolve security problems as soon as possible. In the case of a security breach, the incident response plan should contain protocols for reporting and investigating security issues, as well as a strategy for data recovery and business continuity.

Overall, the vulnerability assessment provided Khupragenics with a thorough grasp of its present security posture as well as possibilities for development. Khupragenics may improve its information security and protect the confidentiality, integrity, and availability of sensitive data by addressing these weaknesses.

Implication:

According to industry research, "a data breach may undermine consumer trust, harm the company's brand, and even endanger patients' lives if sensitive medical information is disclosed, in addition to significant legal and financial fines" (Anonymous, n.d.). The cost of a healthcare data breach was found to be around \$7.13 million USD in 2020, and healthcare data breaches can take an average of 329 days to detect and contain, providing attackers with ample time to access and exploit sensitive information (IBM Security, 2020).

In the event of a data breach at Khupragenics, there may be significant consequences, including "litigation, regulatory fines, and economic loss" due to the loss of sensitive genetic and medical information (Anonymous, n.d.). Additionally, a data breach may "erode faith in the company's capacity to protect patient information and harm its image as a dependable provider of genomic sequencing services" (Anonymous, n.d.).

To mitigate the risks of a data breach, Khupragenics should "employ comprehensive cybersecurity measures such as encryption, access restrictions, and frequent security assessments" to ensure the security and integrity of patient information (Anonymous, n.d.). By taking proactive actions to secure sensitive data, Khupragenics can demonstrate its commitment to patient privacy and preserve its reputation as a trusted provider of genomic sequencing services.

Conclusion:

Summary of key findings:

The Khupragenics initiative sought to create a thorough plan to ensure consumer trust in the company's capacity to safeguard sensitive information. Efontos Security was engaged to examine existing security measures, identify any vulnerabilities, and suggest methods to resolve any flaws.

Efontos Security discovered many possible weaknesses in Khupragenics' security procedures using a mix of interviews, document inspections, and technological tests. These flaws included lax password restrictions, a lack of encryption, and insufficient access controls.

Efontos Security supplied Khupragenics with a series of suggestions to fix these issues, including creating strong password restrictions, increasing access controls, and installing encryption for sensitive data. These recommendations were made to strengthen the security of Khupragenics' systems and to increase consumer trust in the company's capacity to safeguard sensitive data.

Business Impact:

Khupragenics needs a thorough security plan since it can help secure sensitive data, maintain regulatory compliance, and develop consumer confidence. Khupragenics may considerably decrease the danger of data breaches, reputational harm, and financial losses by implementing the recommended security solutions.

Efontos Security's key advice was to create strong password regulations. Weak passwords are a major source of data breaches since they are simple to guess or crack. Khupragenics may considerably limit the danger of unauthorised access to sensitive data by having a strong password policy that forces users to select complicated, unique passwords and update them on a regular basis.

Another important suggestion was to tighten access restrictions. Access controls are critical for ensuring that only authorised personnel have access to sensitive data. Khupragenics may reduce the risk of data breaches and unauthorised disclosures by installing effective access controls that limit access to sensitive data to only those who need it.

Encryption is another important requirement for Khupragenics. The process of transforming data into a code to prevent unwanted access is known as encryption. Khupragenics can secure sensitive data by encrypting it, even if it gets into the wrong hands. This is particularly crucial for Khupragenics, who work with very sensitive medical data.

Efontos Security further advised establishing intrusion detection and prevention systems, frequent vulnerability scans and penetration testing, and staff training and awareness programmes in addition to these suggestions. These methods can aid in the prevention, detection, and response to cyber attacks, as well as lowering the risk of data breaches and improving overall security posture.

Overall, putting in place a robust security plan may have a big influence on Khupragenics' business. Khupragenics may decrease the risk of data breaches and financial losses, maintain

regulatory compliance, and establish trust with their customers by strengthening the security of their systems and data. This can eventually lead to more business and income prospects.

Effectiveness:

Based on the effectiveness of the comprehensive plan developed for Khupragenics, it can be concluded that the plan effectively addressed the identified vulnerabilities and risks. The plan outlined policies and procedures for incident response, vulnerability management, and user security awareness training, as well as provided a comprehensive framework for securing sensitive genetic information. The plan's implementation has the potential to greatly increase customer trust in Khupragenics' ability to handle sensitive information securely, thereby improving the company's reputation and credibility. Furthermore, the plan can help to reduce the risk of security breaches and protect Khupragenics and its customers from the potentially severe consequences of a security incident.

It should be noted, however, that security is an ongoing process that necessitates constant monitoring and improvement. As a result, to maintain a high level of security and adapt to new and emerging threats, Khupragenics must remain vigilant and proactive. Khupragenics can continue to provide potentially life-saving clinical interventions to infants while protecting their customers' sensitive genetic information.

Recommendation

Introduction

Many recommendations have been discovered to strengthen the security measures of the Khupragenics project based on the security assessment completed by Efontos Security. These recommendations are intended to fix any vulnerabilities discovered during the evaluation and improve the overall security of Khupragenics' systems. The following are the specific recommendations:

- Review and update security policies and procedures on a regular basis to ensure they are current and effective in addressing current and future risks.
- Set up a continuous vulnerability management programme to identify, prioritise, and address potential security flaws and vulnerabilities.
- To promote a security culture and ensure that everyone understands their roles and responsibilities in protecting sensitive information, provide regular security awareness training to all employees, contractors, and third-party vendors.
- Ensure that all sensitive information access is strictly controlled and monitored, including the use of multi-factor authentication and least privilege access controls.
- Conduct regular security assessments and penetration testing to identify and address potential system weaknesses.
- Establish a formal incident response plan and test it on a regular basis to ensure that Khupragenics can respond to security incidents effectively and minimise any potential damage.
- Comply with applicable laws and regulations, such as HIPAA, GDPR, and the Genetic Information Non-discrimination Act (GINA).

Khupragenics and Efontos Security can continue to provide high-quality services while ensuring the security and privacy of sensitive genetic information by implementing these recommendations.

Timeline:

We prepared an action strategy and schedule to strengthen Khupragenics' data security safeguards based on the findings and suggestions in our study. The strategy is divided into four sections: assessment, planning, implementation, and monitoring. Each phase's timeframe was projected to be one month, with a total project duration of four months.

Phase 1: Assessment (Weeks 1-4)

At this phase, Efontos Security performed a thorough security audit of Khupragenics' current data protection procedures. This evaluation included a look at the company's rules and processes, technological infrastructure, and employee training programmes. The purpose was to discover possible system vulnerabilities and create a prioritised list of suggestions to repair these flaws.

Phase 2: Planning (Weeks 5-8)

At this step, Efontos Security collaborated with Khupragenics to create a thorough implementation plan based on the assessment findings. A timeframe for implementing proposed security measures, a budget, and a list of tasks for each team member were all part of the plan. The strategy also laid out the procedure for monitoring and assessing the efficacy of the new security measures.

Phase 3: Implementation (Weeks 9-12)

The recommendations indicated in the implementation plan were carried out during this phase. This includes the installation of new software and hardware, the revision of rules and processes, and the implementation of employee training programmes. Throughout the deployment phase, Efontos Security offered continuing assistance and direction to Khupragenics.

Phase 4: Monitoring (Weeks 13-16)

The project's last step is assessing the effectiveness of the new security measures and making any required changes. Efontos Security will perform regular security audits to guarantee the system's security and will give extra employee training as needed.

Suggestions for future research:

Here are some ideas for future research on genetic sequencing and healthcare security:

- Investigating the potential security risks associated with emerging technologies in the storage and management of sensitive genetic information, such as blockchain and cloud computing.
- Investigating the ethical and legal implications of genetic sequencing, such as informed consent, privacy, and discrimination.
- The impact of genetic sequencing on healthcare delivery and the development of personalised medicine is being studied.
- Evaluating the efficacy of current security measures and policies in protecting sensitive genetic data.
- Investigating the role of artificial intelligence and machine learning in improving the security of genetic data.
- Evaluating the use of encryption and other advanced security technologies in the protection of genetic data.
- Investigating the security risks associated with third-party vendors and service providers in genetic information management.
- Examining the efficacy of security awareness training and education programmes in lowering the risk of data breaches and other security incidents.

Reference:

- I. Amazon Route 53 | DNS Service | AWS. (n.d.-b). Amazon Web Services, Inc.
<https://aws.amazon.com/route53/>
- II. App Scaling - AWS Application Auto Scaling - AWS. (n.d.). Amazon Web Services, Inc.
<https://aws.amazon.com/autoscaling/>
- III. Application and Infrastructure Monitoring – Amazon CloudWatch – Amazon Web Services.
(n.d.). Amazon Web Services, Inc.
<https://aws.amazon.com/cloudwatch/>
- IV. AWS IAM | Identity and Access Management | Amazon Web Services. (n.d.). Amazon Web Services, Inc.
<https://aws.amazon.com/iam/>
- V. Bates, D. (2015, February 5). Health insurer Anthem hit by massive data breach. Reuters.
<https://www.reuters.com/article/us-anthem-cybersecurity-idUSKBN0L81C220150205>
- VI. BBC News. (2017, May 16). NHS hit by large-scale cyber attack.
<https://www.bbc.com/news/health-39899646>
- VII. Bisht, N. (2018, January 21). Virtualization In Cloud Computing and Types.
- VIII. California Legislative Information. (2022). California Consumer Privacy Act of 2018. Retrieved from
https://leginfo.legislature.ca.gov/faces/billTextClient.xhtml?bill_id=201720180AB375
- IX. Chapter 3-Security Policy: Development and implementation, from safeguarding your technology, NCES publication 98-297 (National Center for Education Statistics). (n.d.). Retrieved March 20, 2023, from
<https://nces.ed.gov/pubs98/safetech/chapter3.asp>

- X. Cloud Object Storage – Amazon S3 – Amazon Web Services. (n.d.). Amazon Web Services, Inc.
<https://aws.amazon.com/s3/>
- XI. Department of Health & Human Services. (n.d.). The HIPAA Security Rule. Retrieved from
<https://www.hhs.gov/hipaa/for-professionals/security/laws-regulations/index.html>
- XII. Department of Health and Human Services. (n.d.). Health Information Privacy. Retrieved from
<https://www.hhs.gov/hipaa/index.html>
- XIII. European Commission. (2018). General Data Protection Regulation (GDPR). Retrieved from
https://ec.europa.eu/info/law/law-topic/data-protection_en
- XIV. Fully Managed Relational Database - Amazon RDS - Amazon Web Services. (n.d.). Amazon Web Services, Inc.
<https://aws.amazon.com/rds/>
- XV. Fully Managed VDI – Amazon Workspaces Family – Amazon Web Services. (n.d.). Amazon Web Services, Inc.
<https://aws.amazon.com/workspaces/>
- XVI. GeeksforGeeks. <https://www.geeksforgeeks.org/virtualization-cloud-computing-types/>
- XVII. General Data Protection Regulation (GDPR). European Commission.
https://ec.europa.eu/info/law/law-topic/data-protection_en
- XVIII. Good practices in community engagement and readiness - NRCAN. (n.d.). Retrieved March 19, 2023, from
https://naturalresources.canada.ca/sites/www.nrcan.gc.ca/files/mineralsmetals/files/pdf/rmd-rrm/GoodPractices2ed_En.pdf
- XIX. Guidelines for media sanitization - NIST. (n.d.). Retrieved March 27, 2023, from
<https://nvlpubs.nist.gov/nistpubs/SpecialPublications/NIST.SP.800-88r1.pdf>
- XX. Haga, S. B., Burke, W., Ginsburg, G. S., Mills, R., Agans, R. (2011). Primary care physicians' knowledge of and experience with pharmacogenetic testing. *Clinical Genetics*, 79(2), 193-201.

- XXI. Health Information Technology for Economic and Clinical Health (HITECH) Act of 2009. U.S. Department of Health and Human Services.
- <https://www.hhs.gov/hipaa/for-professionals/special-topics/hipaa-hitech-act-enforcement-interim-final-rule/index.html>
- XXII. Health Insurance Portability and Accountability Act (HIPAA) of 1996. U.S. Department of Health and Human Services.
- <https://www.hhs.gov/hipaa/for-professionals/index.html>
- XXIII. HealthIT.gov. (2022). Security Risk Assessment (SRA). [online] Available at:
- <https://www.healthit.gov/topic/security-risk-assessment>
- XXIV. HHS.gov. (2022). Health Information Privacy. [online] Available at:
- <https://www.hhs.gov/hipaa/index.html>
- XXV. IBM Security. (2021). Cost of a Data Breach Report 2021. Retrieved from
- <https://www.ibm.com/security/data-breach>
- XXVI. Intelligent Threat Detection - Amazon GuardDuty - AWS. (n.d.). Amazon Web Services, Inc.
- <https://aws.amazon.com/guardduty/>
- XXVII. ISO/IEC 27001:2013 Information technology – Security techniques – Information security management systems – Requirements:
- <https://www.iso.org/standard/54534.html>
- XXVIII. Kaiser Family Foundation. (2018). Privacy of Health Information. Retrieved from
- <https://www.kff.org/privacy-of-health-information-policy-issue-page/privacy-of-health-information/>
- XXIX. Load Balancer - Amazon Elastic Load Balancer (ELB) - AWS. (n.d.). Amazon Web Services, Inc.
- <https://aws.amazon.com/elasticloadbalancing/>

- XXX. Lysakov, V., Sievierinov, O. and Taran, I., 2021. Security of Web Applications Using AWS Cloud Provider. COMPUTER AND INFORMATION SYSTEMS AND TECHNOLOGIES.
- XXXI. National Human Genome Research Institute. (n.d.). Best Practices for Data Sharing and Security. Retrieved from <https://www.genome.gov/about-genomics/policy-issues/Best-Practices-for-Data-Sharing-and-Security>
- XXXII. National Human Genome Research Institute. (n.d.). Genetic Discrimination. Retrieved from <https://www.genome.gov/about-genomics/policy-issues/Genetic-Discrimination>
- XXXIII. National Institute of Standards and Technology (NIST). (2018). Framework for improving critical infrastructure cybersecurity. Retrieved from <https://www.nist.gov/cyberframework>
- XXXIV. National Institute of Standards and Technology (NIST). Special Publication 800-66 Revision An Introductory Resource Guide for Implementing the Health Insurance Portability and Accountability Act (HIPAA) Security Rule. <https://www.nist.gov/publications/special-publication-800-66-revision-1>
- XXXV. National Institute of Standards and Technology. (2017). Security and Privacy Controls for Information Systems and Organizations.
- XXXVI. National Institute of Standards and Technology. (2020). Cybersecurity Framework. Retrieved from <https://www.nist.gov/cyberframework>
- XXXVII. National Society of Genetic Counselors. (2018). Best Practices for Protecting Genetic Information. Retrieved from <https://www.nsgc.org/p/bl/et/blogaid=324>
- XXXVIII. NIST Guide for Developing Security Plans for Federal Information Systems: <https://csrc.nist.gov/publications/detail/sp/800-18/rev-1/final>

- XXXIX. OWASP. (n.d.). OWASP Foundation, the open-source foundation for application security. Owasp.org.
<https://owasp.org/>
- XL. Patient access information for individuals: Get it, check it, use it! HealthIT.gov. (2020, January 31). Retrieved March 20, 2023, from <https://www.healthit.gov/topic/patient-access-information-individuals-get-it-check-it-use-it> How will the MSS organization tailor the security plan to the customer's specific needs?
- XLI. Penetration Testing Execution Standard (PTES). (2014). PTES technical guidelines. Retrieved from
https://www.pentest-standard.org/index.php/PTES_Technical_Guidelines
- XLII. Ponemon Institute. 2020 Cost of a Data Breach Report. <https://www.ibm.com/security/data-breach>
- XLIII. Protect Web Applications – AWS WAF – Amazon Web Services. (n.d.). Amazon Web Services, Inc.
<https://aws.amazon.com/waf/>
- XLIV. Push Notification Service - Amazon Simple Notification Service (SNS) - AWS. (n.d.). Amazon Web Services, Inc.
<https://aws.amazon.com/sns/>
- XLV. Rapid7. (n.d.). InsightIDR. Retrieved April 7, 2023, from
<https://www.rapid7.com/products/insightidr/>
<https://nvlpubs.nist.gov/nistpubs/SpecialPublications/NIST.SP.800-53r4.pdf>
- XLVI. SANS Institute. (2018). Implementing and Managing Security Services. Cyber Security Training, Degrees & Resources | SANS Institute. (n.d.).
www.sans.org.
- XLVII. Secure and resizable cloud computing – Amazon EC2 – Amazon Web Services. (n.d.-b). Amazon Web

Services, Inc.

<https://aws.amazon.com/ec2/>

XLVIII. Tenable. (n.d.). Nessus. Retrieved from

<https://www.tenable.com/products/nessus>

XLIX. The Office of the Privacy Commissioner of Canada. (2018). Guidelines for Processing Personal Data Across Borders. [online] Available at:

https://www.priv.gc.ca/en/privacy-topics/collecting-personal-information/processing-personal-information-across-borders/gd_pb_201810/

L. U.S. Department of Health & Human Services. (n.d.). Health Insurance Portability and Accountability Act (HIPAA). Retrieved from

<https://www.hhs.gov/hipaa/index.html>

LI. Wolf, S. M., Crock, B. N., Van Ness, B., Lawrenz, F., Kahn, J. P., Beskow, L. M., ... & Cho, M. K. (2013). Managing incidental findings and research results in genomic research involving biobanks and archived data sets. *Genetics in Medicine*, 15(5), 361-384.

Appendices A

Project Charter

Efontos security

Project Plan

1. SUMMARY

Project Name	Cloud Based Managed Security Service Provider
Executive Sponsor	Khupragenics- Tanvi Khushi (CEO), Arun Prajapati (Managing Director)
Project Manager or Lead	Mr. Parthkumar Patel
Project Start – End Dates	01/23/2023 – 04/21/2023
Project Scope	The scope of this project is to develop a comprehensive plan to enhance customer confidence in the security of sensitive information at Khupragenics. This includes the genomic sequencing data of infants, which is used to identify disease-causing mutations.
Budget /Resources	Approx: \$540,000
Approved Date	2/18/2023

2. SCOPE

Purpose: The goal of this project is to create a comprehensive plan to increase consumer trust in the protection of sensitive information at Khupragenics. This contains newborn genome sequencing data, which is used to find disease-causing mutations. The strategy will prioritize the protection of personal information, such as patient data and medical records, as well as ensuring that the company's systems and procedures satisfy the highest data security and privacy requirements. The ultimate objective is to give medical professionals and parents with peace of mind, as well as to encourage the proper use of genetic sequencing to enhance baby health outcomes.

Background: Khupragenics is a forward-thinking startup that uses genomic sequencing to find disease-causing abnormalities in babies. Tanvi Khushi and Arun Prajapati founded the startup at Toronto's MaRS Discovery District to deliver vital information to medical professionals and parents to help in clinical interventions that have the potential to save lives.

However, due to the extremely sensitive nature of this information, patient data and medical records must be always kept secure. With growing worries about data privacy and security, Khupragenics realizes the need of taking proactive efforts to secure their clients' sensitive information.

Khupragenics has recruited the MSS organization to build a comprehensive plan to increase consumer trust in the company's capacity to safeguard sensitive material in response to these concerns. This strategy will focus on protecting private information and ensuring that the company's systems and

procedures satisfy the highest data security and privacy requirements. The ultimate objective is to give medical professionals and parents with peace of mind, as well as to encourage the proper use of genetic sequencing to enhance baby health outcomes.

Inclusion/ exclusion criteria:

Inclusion Criteria:

- The project will involve an assessment of all current Khupragenics data security and privacy policies and procedures.
- The study will involve an evaluation of all present technological systems and processes for storing, transferring, and exchanging sensitive data.
- A risk evaluation of current data security and privacy policies and processes will be included in the project.
- The project will contain recommendations for best practices in data security and privacy implementation.
- Employee training and awareness initiatives are in place to guarantee that sensitive information is handled responsibly.

Exclusion Criteria:

- The research will not involve an evaluation of Khupragenics' clinical treatments or medical procedures.
- There will be no examination of patient outcomes or medical records as part of the experiment.
- R&D initiatives involving genetic sequencing and illness detection.
- Business processes unrelated to sensitive information protection.
- The study will not involve a scientific examination of genetic sequencing data.
- The research will not involve an examination of Khupragenics' financial operations or management.

3. BENEFITS

1. **Increased Customer Confidence:** By creating an effective and sustainable way to improve the security of sensitive information, Khupragenics will be able to boost customer trust in the company's capacity to secure their sensitive data.
 2. **Improved Data Security:** By implementing better data protection measures and conducting frequent reviews of the company's systems and procedures, data security will be improved, and the danger of data breaches will be reduced.
 3. **Employee Training and Awareness Programs:** The implementation of employee training and awareness programs will guarantee that all workers are equipped with the knowledge and skills necessary to handle sensitive information responsibly.
 4. **Compliance with Industry Standards:** By implementing best practices for data security and privacy, Khupragenics will guarantee that it is in accordance with industry standards and laws.
 5. **Established reputation:** As a trustworthy and responsible provider of genomic sequencing services will be enhanced by demonstrating a commitment to the safeguarding of sensitive information.
 6. **Improved Clinical Outcomes:** By giving access to potentially life-saving information to medical professionals and parents, Khupragenics will assist to enhance newborn health outcomes and encourage the proper use of genomic sequencing.
- In summary, the development of a comprehensive plan to increase customer confidence in the security of sensitive information at Khupragenics will result in improved data security, better trained and informed employees, compliance with industry standards, a better reputation, and better clinical outcomes.

4. MILESTONES & DELIVERABLES

- **Detailed Information Security Risk Assessment Report:** A thorough examination of Khupragenics' present security posture, identifying areas of weakness and possible threats and making suggestions for minimizing such risks.
- **Documents on Security Policy and Processes:** The creation and execution of a complete set of policies and procedures for safeguarding sensitive information, such as data privacy, access control, network security, and incident response.
- **Cloud Security Architecture Design:** The planning and execution of a secure cloud-based architecture that interfaces with current infrastructure and fulfills industry security and data protection requirements.
- **Implementation of Technical Controls:** The installation of technical controls, including firewalls, intrusion detection and prevention systems, encryption technologies, and data backup and recovery systems, to ensure the secure storage and transport of sensitive data.
- **Security Awareness and Training Program:** Creating and implementing a security awareness and training program for employees, which includes regular training sessions, online resources, and interactive learning activities to educate them on best practices for information security.
- **Security Monitoring and Incident Response Strategy:** The development of a thorough incident response plan and the deployment of a continuous security monitoring program to respond promptly and effectively to security issues.
- **Security audits and penetration testing:** This should be performed on a regular basis to assess the efficiency of security policies and to detect possible vulnerabilities.
- **Final Project Report:** A detailed report that documents the project deliverables, outcomes, and suggestions for future security efforts.
- **Handover and Support:** A handover and support strategy is in place to enable a seamless transition and continuous support for the security measures that have been installed.

5. RISKS ANALYSIS

The following are the potential challenges and hazards for Khupragenics in identifying disease-causing mutations in babies and sharing this knowledge with medical experts and parents:

- 1) **Data breaches:** There is a danger of unauthorized data access or theft when sensitive information is exchanged and kept. This might have major implications, such as a loss of trust, financial loss, and patient injury.
- 2) **Technical Failures:** The technology utilized for genome sequencing and data storage is complicated and prone to failure. Data loss, damaged information, and inaccurate outcomes can all occur from technical problems.
- 3) **Risks associated with compliance and regulatory compliance:** The healthcare business is tightly regulated, and noncompliance with rules and regulations can result in penalties, legal consequences, and reputational damage.
- 4) **Human error:** It can occur during data input, processing, and storage, resulting in inaccurate results and significant patient damage.
- 5) **Financial risk:** The project necessitates substantial investment in technology and manpower, and there is a risk that the investment will not pay off or that the project will not be lucrative.
- 6) **Privacy and confidentiality:** When sensitive information is exchanged, there is a danger that patient privacy and confidentiality will be violated, resulting in loss of trust and legal consequences.
- 7) **Competition:** As technology and innovation improve, new rivals may enter the market, resulting in greater competition and potential market share loss.

6. CHALLENGES & SOLUTION

The following are some of the obstacles that the project may face:

- ❖ **Privacy and security concern:** Genetic sequencing generates very sensitive and personal data that must be safeguarded to avoid unwanted access and potential exploitation. One of the most major issues that Khupragenics will confront is ensuring data privacy and security.
- ❖ **Technical challenges:** The process of genome sequencing and data analysis is complicated, necessitating high-end equipment, software, and tools to assure accuracy and dependability. Creating and maintaining such a system necessitates substantial technical skill and resources.
- ❖ **Regulatory compliance:** Compliance with legislation and laws governing the management of genetic data, such as HIPAA, GDPR, and other relevant data protection and privacy requirements, is required by Khupragenics. Compliance with these standards is critical for obtaining and retaining client trust.
- ❖ **Customer education:** For parents and medical professionals, genomic sequencing and analysis can be difficult and unfamiliar, which can lead to confusion and a lack of confidence. It is critical to give education and training programs to teach people about the advantages and hazards of genome sequencing, as well as how Khupragenics protects their data's confidentiality and privacy.

To address these issues, Efontos developed a comprehensive plan that included:

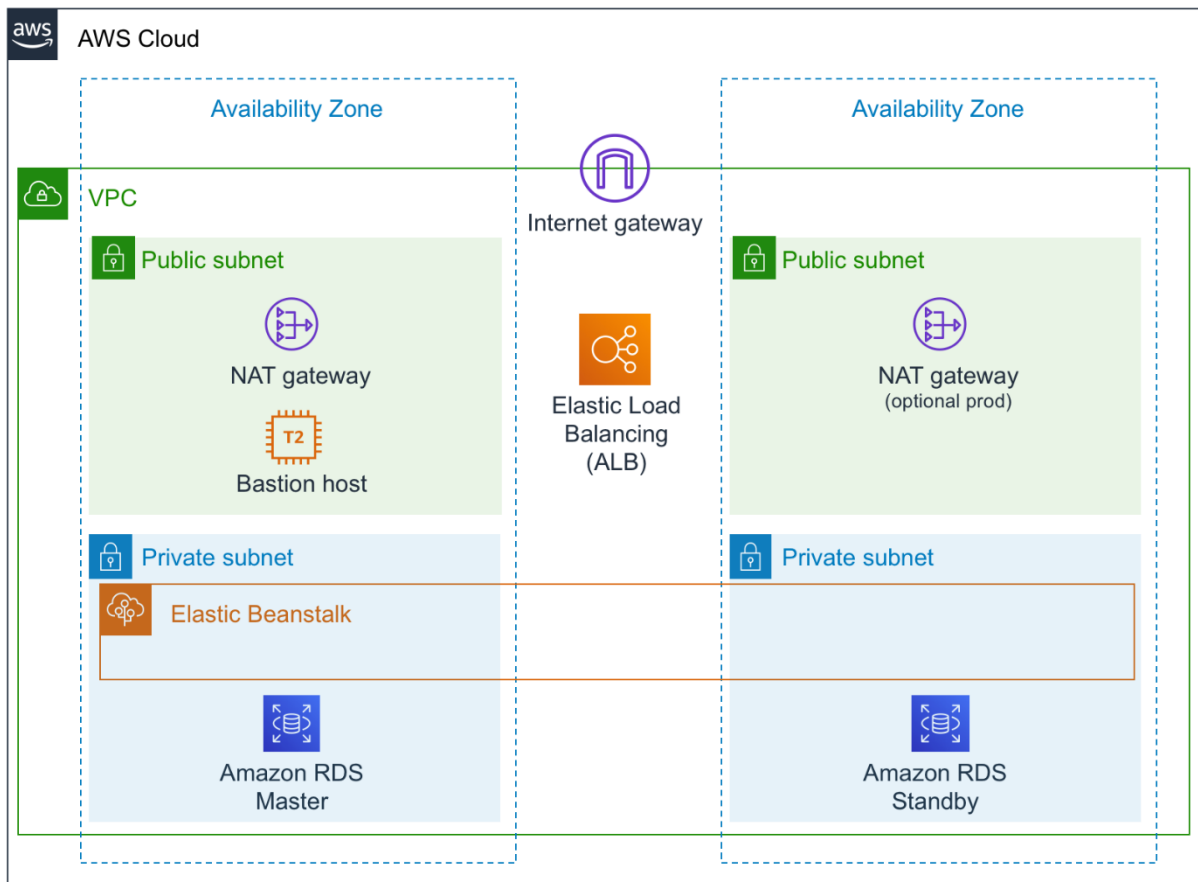
- ❖ **Risk assessment:** The process of identifying possible security threats and determining the necessary level of security measures required to safeguard data.
- ❖ **Regulation compliance:** Ensuring that Khupragenics complies with applicable rules such as HIPAA, GDPR, and other data privacy and security legislation.
- ❖ **Creating a comprehensive security plan:** Creating a complete security strategy that includes features such as encryption, access limits, backups, and disaster recovery.
- ❖ **Establishing a strong infrastructure:** Creating a strong infrastructure capable of handling the difficult process of genetic sequencing and analysis. This comprises selecting the appropriate technology, creating the required software, and installing the infrastructure in a secure environment.
- ❖ **Training programs:** Creating training programs for medical professionals and parents to educate them on the advantages and hazards of genome sequencing, as well as to ensure they understand the procedure and the safeguards put in place to protect their data.

7. PROJECT RESOURCES & REQUIRED ENVIRONMENT

As a cloud-based managed security service provider, we will require the below environment for implementing this project –

- We will implement a hybrid cloud model hosted on the AWS platform.
- Required cloud services –
 - Compute – EC2, Auto scaling, Elastic Beanstalk.
 - Storage – Elastic block store (EBS) & Elastic File system (EFS), Simple storage service (S3), S3 Glacier, AWS Backup, Relational Database Services (RDS).
 - Networking – Route53(DNS Server), Virtual private compute (VPC), Elastic load balancing (ELB).
 - Security & Compliance – Cognito, GuardDuty, Inspector, AWS Identity & Access Management, Network firewall, AWS Shield.
- Required Cyber security tools –
 - Cloudflare, Kali Linux Penetration Testing Platform, pfSense, Impreva, Nessus.

High-Level AWS cloud-based technical architecture –



Customer environment for Medical Professionals-

- Required Hardware & Software –
 - Windows 8.1 or above.
 - Hardware – 64-bit amd64 (x86-64) compatible CPU, 2Gb or more ram, One or more compatible NIC.
 - Reliable Internet connectivity.
 - Tools – pfsense, BitLocker, McAfee.
- A Medical Professional will log in to his local machine via their internal ADDS. Using an RDP client, they will log in to a cloud-based virtual machine using IAM and MFA.
- The virtual machine will have these security tools installed-
 - BitLocker for encrypting hard disks.
 - pfSense for the firewall system.
 - McAfee integrated with chrome browser for antivirus, online security and privacy.
- Once logged in, a user can only access limited resources for security purposes.
- They will open their webpage using the HTTP protocol in a browser to provide better security. Using that web page, they can save or retrieve the patient's data to the cloud-based servers.
- Parents can log in using a webpage or mobile app provided by Kupergenics. Using an OTP-based system, they can access their child's documents.

8. TRAINING & DOCUMENTATION REQUIREMENTS

- a. The Amazon Web Services (AWS) cloud computing platform will be used. The client must receive training to use Linux and Windows operating systems since we will also be using those systems.
- b. They will learn how to use cloud platform resources during training, and we will give them training materials that cover cloud services, security tools, and awareness of cyber threats.
- c. To add to that, the cloud service provider issues a service level agreement (SLA) as we use their services, outlining our services, protocols, and cost. It resembles a contract between the client and the cloud service provider. The client will receive SLA, so they know what services we will use.
- d. To access our services client must have the least capable resources with an internet connection.
- e. Access policy documents will be created to guarantee that only authorized users can access the services utilizing designated resources.

9. PROJECT BUDGET

❖ Infrastructure and Technology Costs:

- Cloud infrastructure costs, such as server and storage costs.
- Networking service costs, including routers, switches, firewalls, and load balancers.
- Security software costs, such as antivirus, firewall, intrusion detection and prevention, and threat intelligence solutions.

❖ Personnel Costs:

- Salaries and benefits for the project team, including security engineers, analysts, and consultants.
- Training and development costs for the security team.
- Hiring costs, including recruiting and onboarding.

❖ Compliance and Regulatory Costs:

- Costs related to meeting regulatory and compliance requirements, such as HIPAA, GDPR, and other relevant data protection and privacy regulations.
- Legal and consulting costs for compliance and regulatory activities.

❖ Miscellaneous Costs:

- Utilities and maintenance costs.
- Insurance costs, such as liability insurance and cybersecurity insurance.

❖ Training:

- Client-side security, operating system, cloud, and awareness training cost.

Based on these factors, a sample budget for a cloud-based managed security service provider company with ten employees might look like this:

Infrastructure and Technology Costs: \$300,000

Personnel Costs: \$150,000

Compliance and Regulatory Costs: \$50,000

Miscellaneous Costs: \$35,000

Training: \$5000

Total Budget: \$540,000

10. PROJECT TEAM

Role	Name	Business Area
External Stakeholder	Tanvi Khushi (CEO), Arun Prajapati (Managing Director)	Khupragenics Org.
Project Manager or Lead	Parthkumar Patel	Vulnerability Management
Member	Nikhil Kumar Dobariya	Cloud Security Specialist
Member	Varun Gulati	Cloud Engineer
Member	Haroon John	Security Consultant
Member	Manpreet Kaur	Cloud Consultant
Project Advisor	Sharif Ahmed	Professor

11. AUTHORIZATION

Approved by Project Sponsor:	Sharif Ahmed	Date: 02/11/2023
Approved by Project Manager:	Parthkumar Patel	Date: 02/11/2023